

ALLGEMEINES KI-IT-SICHERHEITSKONZEPT

Audit- und zertifizierungsvorbereitende Referenz für vollständig lokale KI-
Infrastrukturen

ÖFFENTLICH – organisationsneutrale Referenzvorlage

Version 0.1.0 · Fachlicher Stichtag 02.09.2026

Keine amtliche Veröffentlichung · keine Systemfreigabe · kein Zertifikat

Dokumentenlenkung

Merkmal	Festlegung
Dokumenttitel	Allgemeines KI-IT-Sicherheitskonzept
Dokumentstatus	ÖFFENTLICH – organisationsneutrale Referenzvorlage
Version	0.1.0
Fachlicher Stichtag	02.09.2026
Normative Quelle	katalog/ki-it-sicherheitskatalog.oscal.json
OSCAL-Fassung	1.1.3
Betriebsmodell	vollständig lokal; externe Inferenz nicht anwendbar
Modelländerung	Training und Feinabstimmung ausgeschlossen
Herausgeberschaft	Organisationsneutrales Referenzprojekt; keine amtliche Herausgeberschaft

Freigabehinweis: Diese Fassung enthält ausschließlich öffentliche, organisationsneutrale Informationen. Eine private Repository-Sichtbarkeit ist keine Freigabe für organisationsspezifische, vertrauliche oder eingestufte Inhalte.

Inhaltsverzeichnis

- 1 Dokumentenlenkung und Status ÖFFENTLICH
- 2 Zweck, Zielgruppe und Abgrenzung
- 3 Voraussetzungen des allgemeinen IT-Sicherheitskonzepts
- 4 Lokale KI-Referenzarchitektur
- 5 Systemgrenzen, Vertrauenszonen und Datenflüsse
- 6 Rechts-, Normen- und Anwendbarkeitsmatrix
- 7 Governance, Rollen und Verantwortlichkeiten
- 8 KI-Risiko- und Bedrohungsmodell
- 9 Sicherheitsmaßnahmen entsprechend dem OSCAL-Katalog
- 10 RAG-, Upload- und Datenkonzept
- 11 Agentische Anwendungen und lokale Entwicklungsumgebungen
- 12 Betrieb, Änderung, Modellwechsel, Vorfälle und Außerbetriebnahme
- 13 Nachweis-, Prüf- und Mappingübersicht
- 14 Verfahren zur organisationsspezifischen Übernahme
- 15 Quellenverzeichnis, Glossar und Abkürzungen

1 Dokumentenlenkung und Status ÖFFENTLICH

Dieses Dokument trägt den Status ÖFFENTLICH – organisationsneutrale Referenzvorlage. Es ist eine organisationsneutrale Referenz und keine amtliche Veröffentlichung einer genannten Behörde. Version 0.1.0 bildet denselben Kontrollbestand wie der zugehörige OSCAL-Katalog ab.

Sobald reale Organisations-, Infrastruktur-, Schutzbedarfs-, Konto- oder Schwachstelleninformationen ergänzt werden, endet der öffentliche Status. Die Anpassung erfolgt nur in einer getrennten Offline-Fassung; Einstufung und Freigabe bleiben befugten Stellen der übernehmenden Organisation vorbehalten.

- Redaktionelles Master: DOCX; die PDF-Lesefassung wird ausschließlich daraus erzeugt.
- Normative Anforderungen: OSCAL-Katalog; dieses Dokument erläutert Anwendung und Zusammenwirken.
- Änderungslenkung: gemeinsame Versionierung von Katalog, DOCX und PDF sowie vollständige Quellen- und Prüfspur.
- Konformitätsgrenze: keine automatische ISO-, BSI-, EU-AI-Act-, VS- oder Systemkonformität und kein Zertifikat.

2 Zweck, Zielgruppe und Abgrenzung

Zweck ist eine prüfbare Referenz für Planung, Freigabe, Betrieb, Änderung und Außerbetriebnahme lokaler generativer KI-Dienste. Adressiert werden Leitung, Informationssicherheit, Datenschutz, Recht, Geheimschutz, Personalvertretung, Fachverantwortung, Architektur, Plattform-, Netz-, Identitäts-, RAG-, Modell-, Test- und Betriebsrollen.

Nicht Gegenstand sind eine produktive Plattform, Beschaffungsempfehlungen, Training, Feinabstimmung, kontinuierliches Lernen oder die pauschale Freigabe eines konkreten Anwendungsfalls. Domainwissen wird über lokale RAG-Bestände oder kontrollierte lokale On-Demand-Uploads bereitgestellt.

3 Voraussetzungen des allgemeinen IT-Sicherheitskonzepts

Die Referenz setzt ein wirksames allgemeines IT-Sicherheitskonzept voraus. Die folgenden Fähigkeiten werden nicht vollständig erneut spezifiziert, sondern nur dort verschärft, wo KI-spezifische Daten-, Modell-, Prompt-, RAG- oder Toolrisiken dies verlangen:

- Verwaltete Clients und Server, sichere Domäne, lokaler Identitätsprovider, Rollen und MFA.
- Interne PKI, vertrauenswürdige Zertifikate, Segmentierung, Firewalls und abgesicherter Fernzugriff.
- Patch-, Schwachstellen-, Konfigurations- und sichere Softwareverteilung.
- Lokale Protokollierung, Überwachung, Backup, Wiederherstellung, Notfallmanagement und Schadsoftwareschutz.

KI-GEL-001 verlangt für jede Übernahme den expliziten Bezug auf diese Basis. Fehlende Basismaßnahmen werden nicht durch den KI-Katalog geheilt und müssen im allgemeinen Sicherheitsprozess behandelt werden.

4 Lokale KI-Referenzarchitektur

Die Standardarchitektur ist vollständig lokal. Verwaltete Clients erreichen über HTTPS ausschließlich einen kontrollierten internen KI-Zugang. Dahinter liegt eine getrennte KI-Serverzone mit lokaler Containerplattform, Chat-Oberfläche, Inferenz, RAG, Embeddings, Reranking, Vektor- beziehungsweise Datenbank und technischer Überwachung. Fernzugriff erfolgt nur über ein organisationskontrolliertes VPN mit MFA.

Clientzone →	Kontrollierter KI-Zugang →	KI-Serverzone
Browser · agentische Clients · lokales Git Ausgehend ausschließlich HTTPS	IdP · Rollen · TLS Modell- und Toolfreigabe Protokollierung · Begrenzung	Chat · Inferenz · RAG Embeddings · Datenbank Monitoring · kein Egress

Abbildung 1: Abstrakte lokale Referenzarchitektur. Produkte sind austauschbare Beispiele.

5 Systemgrenzen, Vertrauenszonen und Datenflüsse

Vertrauenszone	Aufgabe und Grenze
Verwaltete Clientzone	Benutzerinteraktion, lokale Entwicklungswerkzeuge und begrenzte agentische Aktionen.
Kontrollierter KI-Zugang	Einziger Clientpfad; Identität, Rollen, TLS, Modell-, Kontext-, Raten- und Toolregeln.
KI-Serverzone	Interne Inferenz-, RAG-, Daten- und Überwachungsdienste ohne öffentliches oder allgemeines Clientnetz-Exposure.
Importweg	Prüfung von Modellen, Images, Paketen und Erweiterungen vor Übernahme in lokale Registrierungen.
Betriebs- und Nachweisbereich	Besonders geschützte Protokolle, SIEM-Daten, Freigaben, Sicherungen und Wiederherstellungsdaten.

Das interne Container- oder Pod-Netz gilt nicht als hinreichende Sicherheitsgrenze. Kommunikationsbeziehungen werden standardmäßig verweigert und ausdrücklich erlaubt. Inferenz-, Administrations-, Debug-, Metrik-, Cluster- und Cache-Ports bleiben vom normalen Netz getrennt.

Alle fachlichen Datenflüsse bleiben lokal: Identitäten, Git, Modelle, Dokumente, Embeddings, Indizes, Chats, Protokolle, Telemetrie und Sicherungen. Der Standardbetrieb besitzt keinen Internet-Egress. Artefaktimporte erfolgen über einen kontrollierten separaten Prozess.

6 Rechts-, Normen- und Anwendbarkeitsmatrix

Grundlage	Anwendbarkeit	Erforderliche organisationsspezifische Klärung	Quellen
KI-Verordnung (EU) 2024/1689	Anwendungsfallbezogen	Rolle, Risikoklasse, Betreiberpflichten, KI-Kompetenz und Folgenabschätzung prüfen.	Q-EU-001
Datenschutzrecht	Bei personenbezogenen Daten	Rechtsgrundlage, Zweck, Minimierung, Rollen, Transparenz, Rechte, Löschung und Folgenabschätzung prüfen.	Q-BFDI-001; Q-DSK-001 bis Q-DSK-003
BSIG und adressatenbezogene BSI-Vorgaben	Organisationsspezifisch	Adressat, Verbindlichkeit, Basis-Sicherheitskonzept und Nachweispflichten feststellen.	Q-BSIG-001; Q-BSI-001
Geheimschutz	Bei entsprechend geschützten Inhalten	Verarbeitung nur nach befugter Einstufung, Systemzulässigkeit und ausdrücklicher Freigabe.	Q-SUEG-001; Q-VSA-001
ISO/IEC 27001 und 27002	Orientierende Zuordnung	Lizenzierte Normtexte und unabhängige Bewertung für eine Konformitätsaussage erforderlich.	Q-ISO-27001; Q-ISO-27002
ISO/IEC 42001, 23894, 42005, 5338, 5259, 25059	Orientierende KI-Zuordnung	Nur öffentliche Metadaten und Kennungen; keine Wiedergabe proprietärer Anforderungen.	Q-ISO-42001; Q-ISO-23894; Q-ISO-42005; Q-ISO-5338; Q-ISO-5259; Q-ISO-25059

Die Matrix ist ein Prüfungseinstieg und keine Rechtsberatung. Fachgesetze, Mitbestimmung und behörden-spezifische Vorschriften sind je Organisation und Anwendungsfall zu ergänzen.

7 Governance, Rollen und Verantwortlichkeiten

Rolle	Kernverantwortung
Leitung	Risikobereitschaft, Ressourcen, wesentliche Restrisiken und Freigabeframeworken.
KI-Verantwortliche	Inventar, Anwendungsfälle, Modell- und Richtlinienfreigaben sowie koordinierter Lebenszyklus.
Informationssicherheit	Bedrohungsmodell, Kontrollanforderungen, Prüfung, Vorfälle und Basis-ISMS-Verknüpfung.
Datenschutz, Recht, Geheimschutz, Personalvertretung	Anwendbarkeitsprüfung, Beteiligung, Bedingungen und befugte Freigaben im jeweiligen Zuständigkeitsbereich.
Architektur, Netz, Plattform, Identität und Gateway	Technische Zonen, Egress, Laufzeitbaseline, Identitäten, Zertifikate und Richtliniendurchsetzung.
Modell, RAG, Daten und Tools	Provenienz, Integrität, ACLs, Löschung, Erweiterungsfreigabe und fachliche Datenverantwortung.
Test und Betrieb	Reproduzierbare Evaluation, Regression, Monitoring, Protokollierung, Wiederanlauf und Außerbetriebnahme.
Nutzende	Zweckgebundene Nutzung, Schutzregeln, Ergebnisprüfung und Meldung von Auffälligkeiten.

Eine Person kann mehrere Rollen wahrnehmen, sofern Interessenkonflikte und notwendige unabhängige Prüfungen behandelt werden. Verantwortung darf nicht an das Sprachmodell oder eine automatisierte Agentenkette delegiert werden.

8 KI-Risiko- und Bedrohungsmodell

Das Bedrohungsmodell erweitert das allgemeine IT-Modell um probabilistische Ausgaben, untrusted Kontext, Modell- und Wissenslieferketten sowie agentische Wirkungsketten. Es betrachtet Eingabe, Modell, Systemanweisung, RAG, Tool, Client, Schnittstelle, Plattform, Protokoll und Importpfad.

Szenario	Auswirkung	Behandlungsschwerpunkt
Prompt Injection	Direkte oder indirekte Anweisungen überschreiben beabsichtigte Regeln.	Kontexttrennung, Tool-Policy, Bestätigung, Tests und Monitoring.
Poisoning und manipulierte Provenienz	Modell- oder RAG-Artefakte verändern Verhalten und Quellenlage.	Kontrollierter Import, Hash, Signatur, Herkunft, Freigabe und Rollback.
Datenabfluss und Rekonstruktion	Prompts, Embeddings, Caches, Ausgaben oder Tools überschreiten Berechtigungen.	ACL vor Aufnahme und Abfrage, Minimierung, Egress-Verbot und Ausgabeprüfung.
Unsichere Modellausgabe	Fehlerhafte Inhalte oder Code erhalten reale Folgewirkung.	Validierung, menschliche Freigabe, sichere Weiterverarbeitung und Kennzeichnung.
Übermäßige Agentenrechte	Modellfehler führen zu Datei-, Befehls- oder Netzwerkaktionen.	Getrennte Fähigkeiten, Least Privilege, konkrete Bestätigung und Auditspur.
Ressourcenerschöpfung	Kontexte, Schleifen und Last verdrängen lokale Dienste.	Quoten, Timeouts, Queueing, Ressourcenlimits und sichere Beendigung.
Drift und Regression	Geänderte Kette verschlechtert Sicherheit oder Qualität.	Versionierte Freigabe, Regression, Betriebsmetriken und getesteter Rollback.

Bewertungen werden vor Erstnutzung, mindestens jährlich und nach wesentlichen Änderungen wiederholt. Akzeptierte Restrisiken bleiben sichtbar, befristet und einer befugten Rolle zugeordnet.

9 Sicherheitsmaßnahmen entsprechend dem OSCAL-Katalog

Die folgenden Kontrollblöcke übernehmen die normative Anforderung unverändert aus dem OSCAL-Katalog und erläutern Begründung, Referenzumsetzung, Prüfziel und Nachweise. Quellen- und Mappingangaben sind nachvollziehbare Zuordnungen; sie stellen keine Zertifizierung oder behördliche Freigabe dar.

9.1 Geltungsbereich und Abhängigkeit vom Basis-Sicherheitskonzept

KI-GEL-001 – Abgrenzung zum allgemeinen IT-Sicherheitskonzept

Normative Anforderung

Für jede Übernahme dieser Referenz MUSS ein wirksames allgemeines IT-Sicherheitskonzept benannt werden. Die KI-spezifischen Kontrollen dürfen Basismaßnahmen nicht ersetzen; Abhängigkeiten, Verschärfungen und verbleibende Lücken MÜSSEN dokumentiert werden.

Begründung

KI-Komponenten erben Risiken aus Identitätsmanagement, Netzen, Plattformen und Betrieb. Ohne nachweisbare Basis kann die Wirksamkeit der Ergänzungen nicht beurteilt werden.

Umsetzung in der Referenzarchitektur

Eine Anwendbarkeitsmatrix verknüpft jede KI-Komponente mit den einschlägigen Basismaßnahmen und kennzeichnet ausschließlich die KI-spezifische Ergänzung. Fehlende Basiskontrollen werden außerhalb dieses Katalogs behandelt.

Prüfziel

Feststellen, ob Geltungsbereich, referenziertes Basis-Sicherheitskonzept und Abhängigkeiten vollständig und ohne Doppelzählung beschrieben sind.

Erwartete Nachweise

Freigegebenes Basis-Sicherheitskonzept; Anwendbarkeitsmatrix; Systemabgrenzung; dokumentierte Lücken und Verantwortlichkeiten.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Planung; Übernahme; Informationssicherheitsbeauftragte; KI-Verantwortliche; Systemverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: ISMS.1, ORP.1; ISO: ISO/IEC 27001:2022 4.3, ISO/IEC 27001:2022 6.1

Quellen

[Q-BSI-001] S. 4–5 und S. 11–12; [Q-ISO-27001] öffentliche Metadaten; Zuordnung zu ISMS und Risikomanagement¹

¹ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 4–5 und S. 11–12,

KI-GEL-002 – Öffentlicher Referenzstatus und kontrollierte Übernahme

Normative Anforderung

Das öffentliche Referenzrepository MUSS organisationsneutral bleiben. Vor jeder organisationsspezifischen Anpassung MUSS eine getrennte, angemessen geschützte Offline-Fassung erstellt und der Statusmechanismus auf organisationsspezifisch gesetzt werden; die formale Einstufung MUSS durch befugte Organisationsstellen erfolgen.

Begründung

Architektur-, Schutzbedarfs- und Schwachstellenangaben können den Schutzbedarf unmittelbar erhöhen. Repository-Sichtbarkeit ist keine informationsschutzrechtliche Freigabe.

Umsetzung in der Referenzarchitektur

Der maschinenlesbare Projektstatus steuert Deckblatt, Kopfzeilen und Freigabeprüfungen. Heuristiken suchen ergänzend nach Infrastruktur- und Geheimnismustern, ersetzen aber keine manuelle Prüfung.

Prüfziel

Nachweisen, dass die öffentliche Fassung organisationsneutral ist und der Statuswechsel in einer Prüffassung wirksam ausgelöst wird.

Erwartete Nachweise

Projektstatus; negative Statustests; Freigabeprotokoll; Ergebnis der heuristischen Inhaltsprüfung; dokumentierte Zuständigkeit für Einstufungen.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Übernahme; Freigabe; Änderung; Informationssicherheitsbeauftragte; Geheimschutzbeauftragte; Dokumentenverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: ORP.1, CON.10; ISO: ISO/IEC 27001:2022 5.2, ISO/IEC 27002:2022 5.12

Quellen

[Q-SUEG-001] § 4; [Q-VSA-001] allgemeine Einstufungs- und Handhabungsregeln; [Q-BMI-001] S. 26–27²

https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | International Organization for Standardization / International Electrotechnical Commission: Information security, cybersecurity and privacy protection — Information security management systems — Requirements, ISO/IEC 27001:2022, 2022-10-01, öffentliche Metadaten; Zuordnung zu ISMS und Risikomanagement, <https://www.iso.org/standard/27001>, abgerufen am 02.09.2026.

² Bundesrepublik Deutschland: Sicherheitsüberprüfungsgesetz, § 4 Verschlusssachen, SÜG, 1994-04-20, § 4, https://www.gesetze-im-internet.de/s_g/_4.html, abgerufen am 02.09.2026. | Bundesministerium des Innern und für Heimat: Allgemeine Verwaltungsvorschrift zum materiellen Geheimschutz, Verschlusssachenanweisung, 2023-03-13, allgemeine Einstufungs- und Handhabungsregeln, https://www.verwaltungsvorschriften-im-internet.de/bsvwvbund_13032023_SII554001405.htm, abgerufen am 02.09.2026. | Bundesministerium des Innern und für Heimat / Beratungszentrum für Künstliche Intelligenz: Leitlinien für den Einsatz Künstlicher Intelligenz in der Bundesverwaltung, Erstfassung, 2025-04-07, S. 26–27, <https://www.bmi.bund.de/SharedDocs/downloads/DE/publikationen/themen/moderne-verwaltung/ki/BMI25020-leitlinien-ki-bundesverwaltung.html>, abgerufen am 02.09.2026.

9.2 KI-Governance, Inventar, Rollen und Nutzungsgenehmigung

KI-GOV-001 – KI-Inventar und eindeutige Verantwortung

Normative Anforderung

KI-Systeme, Modelle, Schnittstellen, RAG-Bestände, agentische Werkzeuge, Anbieterabhängigkeiten und genehmigte Anwendungsfälle MÜSSEN in einem verantworteten Inventar geführt werden. Für jeden Eintrag MÜSSEN fachliche, technische, informationssicherheits- und datenschutzbezogene Rollen benannt sein.

Begründung

Nicht erfasste Modelle oder Integrationen entziehen sich Risiko-, Änderungs- und Außerbetriebnahmesteuerung.

Umsetzung in der Referenzarchitektur

Das Inventar enthält Version, Herkunft, Einsatzzweck, Datenarten, Schutzbedarf, Eigentümer, Freigabestatus, Abhängigkeiten und Ablauf der nächsten Überprüfung.

Prüfziel

Stichprobenartig prüfen, ob bereitgestellte Komponenten und genehmigte Nutzungen vollständig im Inventar abgebildet und Verantwortliche handlungsfähig sind.

Erwartete Nachweise

KI-Inventar; Rollenmatrix; Komponentenabgleich; Reviewprotokolle; Freigabestatus.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Planung; Beschaffung; Betrieb; Außerbetriebnahme; Leitung; KI-Verantwortliche; Systemverantwortliche; Datenschutzbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: ORP.1, OPS.1.1.2; ISO: ISO/IEC 42001:2023 A.3, ISO/IEC 27001:2022 5.3

Quellen

[Q-BSI-001] S. 8–10; [Q-BMVG-001] S. 24–28; [Q-EU-001] Art. 9 und 26³

³ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 8–10, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, 2026-08-04, S. 24–28, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | Europäische Union: Verordnung (EU) 2024/1689 über künstliche Intelligenz, ABl. L 2024/1689, 2024-07-12, Art. 9 und 26, <https://eur-lex.europa.eu/eli/reg/2024/1689/oj>, abgerufen am 02.09.2026.

KI-GOV-002 – Genehmigte Nutzung und KI-Kompetenz

Normative Anforderung

Für jeden Anwendungsfall MÜSSEN Zweck, zulässige Daten, freigegebene Modelle und Werkzeuge, verbotene Handlungen, menschliche Kontrollpflichten und Unterstützungswege festgelegt werden. Nutzende MÜSSEN vor Freischaltung und anschließend risikoorientiert qualifiziert werden.

Begründung

Generative KI kann überzeugend fehlerhafte Ausgaben liefern und Sicherheitsgrenzen über Eingaben oder Werkzeuge umgehen. Wirksame Regeln benötigen anwendungsbezogene Kompetenz.

Umsetzung in der Referenzarchitektur

Nutzungsbedingungen werden am Zugang sichtbar bereitgestellt. Rollenbezogene Schulungen behandeln Datenklassifikation, Prompt Injection, Ergebnisprüfung, Kennzeichnung, Meldewege und Grenzen agentischer Aktionen.

Prüfziel

Prüfen, ob nur genehmigte Anwendungsfälle aktiviert sind und Nutzende die maßgeblichen Grenzen nachweislich verstehen.

Erwartete Nachweise

Nutzungsbedingungen; Schulungsplan; Teilnahme- und Wirksamkeitsnachweise; technische Freigabelisten; Stichproben aus Rollenvergaben.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Einführung; Betrieb; Änderung; KI-Verantwortliche; Fachverantwortliche; Personalentwicklung; Nutzende
Orientierende Zuordnung	BSI/IT-Grundschutz: ORP.3, ORP.4; ISO: ISO/IEC 42001:2023 A.6, ISO/IEC 27002:2022 6.3

Quellen

[Q-BSI-001] S. 8–10 und S. 13; [Q-BMI-001] S. 29–30; [Q-EU-001] Art. 4⁴

⁴ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 8–10 und S. 13, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium des Innern und für Heimat / Beratungszentrum für Künstliche Intelligenz: Leitlinien für den Einsatz Künstlicher Intelligenz in der Bundesverwaltung, Erstfassung, 2025-04-07, S. 29–30, <https://www.bmi.bund.de/SharedDocs/downloads/DE/publikationen/themen/moderne-verwaltung/ki/BMI25020-leitlinien-ki-bundesverwaltung.html>, abgerufen am 02.09.2026. | Europäische Union: Verordnung (EU) 2024/1689 über künstliche Intelligenz, ABl. L 2024/1689, 2024-07-12, Art. 4, <https://eur-lex.europa.eu/eli/reg/2024/1689/oj>, abgerufen am 02.09.2026.

KI-GOV-003 – Lebenszyklus-Risikosteuerung, Ausnahmen und Reviews

Normative Anforderung

KI-spezifische Risiken MÜSSEN vor Erstnutzung, regelmäßig mindestens jährlich und anlassbezogen nach Modell-, Daten-, Tool-, Schnittstellen- oder Architekturänderungen bewertet werden. Ausnahmen und Restrisiken MÜSSEN befristet, verantwortet und ausdrücklich akzeptiert werden.

Begründung

Modelle und Wissensbestände ändern Verhalten, Bedrohungsfläche und Ergebnisqualität auch ohne klassische Softwareänderung.

Umsetzung in der Referenzarchitektur

Ein Risikozyklus verbindet Inventar, Bedrohungsmodell, Tests, Freigaben, Betriebsbeobachtung, Vorfälle und Außerbetriebnahme. Ereignisauslöser werden technisch oder organisatorisch überwacht.

Prüfziel

Prüfen, ob aktuelle Risikobewertungen alle wesentlichen Änderungen und Ausnahmen abdecken und Akzeptanzen befristet sowie befristet sind.

Erwartete Nachweise

Risikoregister; Änderungsereignisse; Reviewkalender; Ausnahmegenehmigungen; Restrisikoakzeptanzen; Maßnahmenverfolgung.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Gesamter-Lebenszyklus; Risikoverantwortliche; KI-Verantwortliche; Informationssicherheitsbeauftragte; Leitung
Orientierende Zuordnung	BSI/IT-Grundschutz: ISMS.1, OPS.1.1.3; ISO: ISO/IEC 27001:2022 6.1, ISO/IEC 42001:2023 6.1, ISO/IEC 23894:2023

Quellen

[Q-BSI-001] S. 8, 10 und 12; [Q-BMVG-001] S. 24–25 und S. 45–47; [Q-NIST-001] Govern-, Map-, Measure- und Manage-Aktionen⁵

⁵ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 8, 10 und 12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, 2026-08-04, S. 24–25 und S. 45–47, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | National Institute of Standards and Technology: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, 2024-07-26, Govern-, Map-, Measure- und Manage-Aktionen, <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>, abgerufen am 02.09.2026.

9.3 Recht, Datenschutz, Mitbestimmung, Schutzbedarf und Geheimschutzgates

KI-REC-001 – Rechts- und Datenschutzprüfung je Anwendungsfall

Normative Anforderung

Vor Freigabe eines Anwendungsfalls MÜSSEN anwendbare Rechtsgrundlagen, Rollen, Zweckbindung, Datenminimierung, Transparenz, Betroffenenrechte, Löschung, erforderliche Datenschutz-Folgenabschätzung und Beteiligungsrechte dokumentiert und durch zuständige Stellen geprüft werden.

Begründung

Die rechtliche Bewertung hängt von Zweck, Daten, Rolle und Wirkung des konkreten Einsatzes ab und kann nicht aus der lokalen Betriebsform allein abgeleitet werden.

Umsetzung in der Referenzarchitektur

Eine Anwendbarkeitsmatrix führt KI-Verordnung, Datenschutzrecht, Informationssicherheitsrecht, Mitbestimmung und fachgesetzliche Anforderungen zusammen. Ergebnisse werden als Freigabebedingungen technisch umgesetzt.

Prüfziel

Feststellen, ob jeder freigegebene Anwendungsfall eine aktuelle, nachvollziehbare und von zuständigen Rollen bestätigte Prüfung besitzt.

Erwartete Nachweise

Rechts- und Datenschutzmatrix; Verzeichnis von Verarbeitungstätigkeiten; Datenschutz-Folgenabschätzung oder dokumentierte Nicht-Erforderlichkeit; Beteiligungs- und Freigabenachweise.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Planung; Freigabe; Änderung; Rechtsstelle; Datenschutzbeauftragte; Personalvertretung; Fachverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: ORP.5, CON.2; ISO: ISO/IEC 42001:2023 4.2, ISO/IEC 27001:2022 4.2

Quellen

[Q-EU-001] Art. 2–4, 26–27; [Q-BFDI-001] Kap. 1–7; [Q-DSK-001] Auswahl bis Beendigung⁶

⁶ Europäische Union: Verordnung (EU) 2024/1689 über künstliche Intelligenz, ABl. L 2024/1689, 2024-07-12, Art. 2–4, 26–27, <https://eur-lex.europa.eu/eli/reg/2024/1689/oj>, abgerufen am 02.09.2026. | Die Bundesbeauftragte für den Datenschutz und die Informationsfreiheit: KI in Behörden – Datenschutz von Anfang an mitdenken, Handreichung für die Bundesverwaltung, 2025-12-22, Kap. 1–7, https://www.bfdi.bund.de/SharedDocs/Downloads/DE/DokumenteBfDI/Dokumente-allg/2025/Handreichung-KI.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Künstliche Intelligenz und Datenschutz, Version 1.0, 2024-05-06, Auswahl bis Beendigung, https://www.datenschutzkonferenz-online.de/media/oh/20240506_DSK_Orientierungshilfe_KI_und_Datenschutz.pdf, abgerufen am 02.09.2026.

KI-REC-002 – Schutzbedarf und Geheimschutzgate

Normative Anforderung

Daten, Prompts, Ausgaben, Embeddings, Indizes, Protokolle und Modelle MÜSSEN einem Schutzbedarf zugeordnet werden. Für Verschlusssachen oder andere besonders geschützte Inhalte MUSS vor jeder Verarbeitung eine ausdrückliche organisationsspezifische Zulässigkeits- und Systemfreigabe vorliegen; die öffentliche Referenz erteilt keine solche Freigabe.

Begründung

Abgeleitete Repräsentationen können schutzbedürftige Inhalte bewahren oder rekonstruierbar machen. Ein generischer KI-Zugang darf keine Geheimschutzentscheidung treffen.

Umsetzung in der Referenzarchitektur

Schutzbedarf und zulässige Verarbeitung werden als technische Richtlinien am Gateway, im RAG-Index, in Uploadregeln und in Toolberechtigungen durchgesetzt. Nicht eindeutig zulässige Inhalte werden abgewiesen.

Prüfziel

Prüfen, ob alle Datenformen erfasst sind und besonders geschützte Inhalte ohne dokumentierte Freigabe zuverlässig blockiert werden.

Erwartete Nachweise

Schutzbedarfsfeststellung; Datenfluss- und Klassifikationsmatrix; Freigaben; technische Richtlinien; negative Verarbeitungstests.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Planung; Nutzung; Änderung; Informationssicherheitsbeauftragte; Geheimschutzbeauftragte; Datenschutzbeauftragte; Datenverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: CON.10, ORP.4; ISO: ISO/IEC 27002:2022 5.12, ISO/IEC 27002:2022 5.13

Quellen

[Q-BMI-001] S. 25–27; [Q-SUEG-001] § 4; [Q-VSA-001] Einstufungs- und Handhabungsregeln; [Q-DSK-003] Kap. 2–5⁷

⁷ Bundesministerium des Innern und für Heimat / Beratungszentrum für Künstliche Intelligenz: Leitlinien für den Einsatz Künstlicher Intelligenz in der Bundesverwaltung, Erstfassung, 2025-04-07, S. 25–27, <https://www.bmi.bund.de/SharedDocs/downloads/DE/publikationen/themen/moderne-verwaltung/ki/BMI25020-leitlinien-ki-bundesverwaltung.html>, abgerufen am 02.09.2026. | Bundesrepublik Deutschland: Sicherheitsüberprüfungsgesetz, § 4 Verschlusssachen, SÜG, 1994-04-20, § 4, https://www.gesetze-im-internet.de/s_g/_4.html, abgerufen am 02.09.2026. | Bundesministerium des Innern und für Heimat: Allgemeine Verwaltungsvorschrift zum materiellen Geheimschutz, Verschlusssachenanweisung, 2023-03-13, Einstufungs- und Handhabungsregeln, https://www.verwaltungsvorschriften-im-internet.de/bsvwvbund_13032023_SII554001405.htm, abgerufen am 02.09.2026. | Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu datenschutzrechtlichen Besonderheiten generativer KI-Systeme mit RAG-Methode, Version 1.0, 2025-10-17, Kap. 2–5, https://www.datenschutzkonferenz-online.de/media/oh/DSK_OH_RAG.pdf, abgerufen am 02.09.2026.

9.4 Lokale Referenzarchitektur und Vertrauensgrenzen

KI-ARC-001 – Explizite Zonen und einziger kontrollierter KI-Zugang

Normative Anforderung

Clientzone, kontrollierter KI-Zugang, KI-Serverzone, Importweg sowie Betriebs- und Nachweisbereich MÜSSEN als Vertrauenszonen beschrieben und technisch getrennt werden. Aus dem Clientnetz DARF nur der kontrollierte HTTPS-Zugang erreichbar sein.

Begründung

Direkte Rohschnittstellen umgehen zentrale Identitäts-, Richtlinien-, Protokollierungs- und Begrenzungsentscheidungen.

Umsetzung in der Referenzarchitektur

Firewall-, Routing-, Proxy- und Dienstkonfigurationen veröffentlichen nur den Gateway-Endpunkt. Interne Inferenz-, Verwaltungs-, Metrik-, Debug-, Cluster- und Cache-Ports werden nicht in das normale Netz gebunden.

Prüfziel

Durch Netz- und Porttests nachweisen, dass erlaubte Flüsse funktionieren und sämtliche internen Schnittstellen aus Client- und Fernzugriffsnetzen unerreichbar sind.

Erwartete Nachweise

Aktuelles Zonen- und Datenflussmodell; Firewall- und Proxyregeln; Portinventar; positive und negative Netztests; Konfigurationsauszüge.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Architektur; Einführung; Betrieb; Netzverantwortliche; Systemverantwortliche; Informationssicherheitsbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: NET.1.1, NET.3.2; ISO: ISO/IEC 27002:2022 8.20, ISO/IEC 27002:2022 8.22

Quellen

[Q-BSI-001] S. 11–12; [Q-BMVG-001] S. 23–26; [Q-ENISA-001] Multilayer framework⁸

⁸ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 11–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, 2026-08-04, S. 23–26, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | European Union Agency for Cybersecurity: Multilayer Framework for Good Cybersecurity Practices for AI, Erstveröffentlichung, 2023-11-15, Multilayer framework, <https://www.enisa.europa.eu/publications/multilayer-framework-for-good-cybersecurity-practices-for-ai>, abgerufen am 02.09.2026.

KI-ARC-002 – Vollständig lokale Datenhaltung und unterbundener Internet-Egress

Normative Anforderung

Inferenz, Identitäten, Git, Ablagen, Registrierungen, Modelle, RAG-Daten, Embeddings, Chatverläufe, Protokolle, Telemetrie und Sicherungen MÜSSEN lokal betrieben werden. KI-Komponenten DÜRFEN im Standardbetrieb keinen Internet-Egress besitzen.

Begründung

Unkontrollierter Egress ermöglicht Datenabfluss, Telemetrie, Lieferkettenzugriffe und unbeabsichtigte Cloud-Fallbacks außerhalb der festgelegten Systemgrenze.

Umsetzung in der Referenzarchitektur

Egress wird technisch standardmäßig verweigert. Aktualisierungen und Artefakte passieren einen getrennten Import-, Malware-, Signatur-, Hash- und Freigabeprozess mit lokalen Spiegeln.

Prüfziel

Prüfen, ob alle genannten Datenklassen lokale Speicherorte besitzen und unerlaubte externe Verbindungen technisch sowie durch Beobachtung ausgeschlossen sind.

Erwartete Nachweise

Datenhaltungsregister; Egress-Regeln; DNS-/Proxyprotokolle; Telemetrie-einstellungen; Importnachweise; negative Verbindungstests.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Architektur; Betrieb; Änderung; Netzverantwortliche; Plattformverantwortliche; Informationssicherheitsbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: NET.1.1, OPS.1.1.10; ISO: ISO/IEC 27002:2022 5.14, ISO/IEC 27002:2022 8.20

Quellen

[Q-BSI-001] S. 9–12; [Q-BMI-001] S. 25–28; [Q-NCSC-001] Secure deployment und operation⁹

⁹ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 9–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium des Innern und für Heimat / Beratungszentrum für Künstliche Intelligenz: Leitlinien für den Einsatz Künstlicher Intelligenz in der Bundesverwaltung, Erstfassung, 2025-04-07, S. 25–28, <https://www.bmi.bund.de/SharedDocs/downloads/DE/publikationen/themen/moderne-verwaltung/ki/BMI25020-leitlinien-ki-bundesverwaltung.html>, abgerufen am 02.09.2026. | UK National Cyber Security Centre und internationale Partner: Guidelines for Secure AI System Development, Version 1.0, 2023-11-26, Secure deployment und operation, <https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development/about-this-document>, abgerufen am 02.09.2026.

9.5 Container-, Inferenz- und API-Sicherheit

KI-CON-001 – Standardmäßig verweigerte Containerkommunikation

Normative Anforderung

Container- und Pod-Kommunikation MUSS standardmäßig verweigert und für dokumentierte Dienstbeziehungen ausdrücklich erlaubt werden. Ein gemeinsames internes Netz DARF nicht als alleinige Sicherheitsgrenze bewertet werden.

Begründung

Kompromittierte Parser, UIs oder Agentendienste könnten sich sonst lateral zu Inferenzdiensten, Datenbanken, Verwaltungs- oder Nachweisschnittstellen bewegen.

Umsetzung in der Referenzarchitektur

Kubernetes NetworkPolicies oder funktional gleichwertige Docker-/Podman-Regeln begrenzen Ingress und Egress je Dienstidentität. Plattformgrenzen werden durch Host-Firewalls ergänzt.

Prüfziel

Durch Soll-Ist-Abgleich und negative Verbindungstests nachweisen, dass ausschließlich modellierte Dienstbeziehungen möglich sind.

Erwartete Nachweise

Kommunikationsmatrix; NetworkPolicies beziehungsweise gleichwertige Regeln; Host-Firewallregeln; automatisierte Netztests; Abweichungsliste.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Architektur; Einführung; Betrieb; Plattformverantwortliche; Netzwerkverantwortliche; Informationssicherheitsbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: APP.3.4, SYS.1.6; ISO: ISO/IEC 27002:2022 8.20, ISO/IEC 27002:2022 8.22

Quellen

[Q-K8S-001] NetworkPolicySpec, ingress und egress; [Q-PODMAN-001] Network management; [Q-BSI-001] S. 11–12¹⁰

¹⁰ The Kubernetes Authors: Kubernetes API Reference: NetworkPolicy v1, Online-Dokumentation, Abrufstand 02.09.2026, NetworkPolicySpec, ingress und egress, <https://kubernetes.io/docs/reference/kubernetes-api/networking/network-policy-v1/>, abgerufen am 02.09.2026. | Podman Project: podman-network, Online-Dokumentation, Abrufstand 02.09.2026, Network management, <https://docs.podman.io/en/latest/markdown/podman-network.1.html>, abgerufen am 02.09.2026. | Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 11–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026.

KI-CON-002 – Minimale Containerprivilegien und unveränderbare Laufzeit

Normative Anforderung

KI-Workloads MÜSSEN ohne unnötige Privilegien, ohne privilegierten Modus, mit minimalen Linux-Fähigkeiten und nach Möglichkeit rootless betrieben werden. Schreibgeschützte Dateisystemanteile und getrennte, eng begrenzte persistente Volumes MÜSSEN eingesetzt werden, soweit die Funktion dies zulässt.

Begründung

Parser und KI-nahe Dienste verarbeiten potenziell feindliche Inhalte. Übermäßige Rechte erhöhen die Auswirkung einer Kompromittierung auf Host, Modelle und Daten.

Umsetzung in der Referenzarchitektur

Sicherheitskontexte, Nutzerkennungen, Capability-Drops, Seccomp- beziehungsweise gleichwertige Profile, Mounts und Volumes werden als freigegebene Baseline geprüft und gegen Drift überwacht.

Prüfziel

Prüfen, ob kein produktiver Workload unbegründete Host-, Geräte-, Kernel- oder Dateisystemrechte besitzt.

Erwartete Nachweise

Freigegebene Laufzeitbaseline; Deployment-Manifeste; effektive Laufzeitkonfiguration; Abweichungsgenehmigungen; Driftberichte.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Einführung; Betrieb; Änderung; Plattformverantwortliche; Systemverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: SYS.1.6, OPS.1.1.2; ISO: ISO/IEC 27002:2022 8.9, ISO/IEC 27002:2022 8.27

Quellen

[Q-DOCKER-001] Rootless mode; [Q-NCSC-001] Secure deployment und operation; [Q-ENISA-001] Infrastruktur- und Komponentenebene¹¹

¹¹ Docker, Inc.: Rootless mode, Online-Dokumentation, Abrufstand 02.09.2026, Rootless mode, <https://docs.docker.com/engine/security/rootless/>, abgerufen am 02.09.2026. | UK National Cyber Security Centre und internationale Partner: Guidelines for Secure AI System Development, Version 1.0, 2023-11-26, Secure deployment und operation, <https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development/about-this-document>, abgerufen am 02.09.2026. | European Union Agency for Cybersecurity: Multilayer Framework for Good Cybersecurity Practices for AI, Erstveröffentlichung, 2023-11-15, Infrastruktur- und Komponentenebene, <https://www.enisa.europa.eu/publications/multilayer-framework-for-good-cybersecurity-practices-for-ai>, abgerufen am 02.09.2026.

KI-API-001 – Zentrale Authentisierung und Autorisierung am KI-Zugang

Normative Anforderung

Jeder Benutzer- und Dienstzugriff auf KI-Funktionen MUSS über HTTPS, eine lokale vertrauenswürdige Identität und serverseitig erzwungene Autorisierung erfolgen. Gemeinsame statische API-Schlüssel DÜRFEN nicht als reguläre Nutzeridentität dienen; Identitäten MÜSSEN einzeln widerrufbar und protokollierbar sein.

Begründung

Einige lokale Inferenzschnittstellen besitzen keine eigene Authentisierung oder schützen mit einem API-Schlüssel nicht sämtliche sensiblen Endpunkte.

Umsetzung in der Referenzarchitektur

Ein lokaler Reverse Proxy oder API-Gateway terminiert TLS, bindet den IdP über OIDC, SAML, LDAP oder gleichwertig an, setzt Rollen und Dienstkonten durch und blockiert direkte Backendzugriffe.

Prüfziel

Mit positiven und negativen Identitäts-, Rollen-, Widerrufs- und Direktzugriffstests nachweisen, dass alle Pfade dieselben Regeln erzwingen.

Erwartete Nachweise

Gateway- und IdP-Konfiguration; Zertifikatsnachweise; Rollenmatrix; Widerrufstest; Zugriffsprotokolle; direkte Backend-Blocktests.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Einführung; Betrieb; Identitätsverantwortliche; Gateway-Verantwortliche; Plattformverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: ORP.4, APP.6, CON.1; ISO: ISO/IEC 27002:2022 5.15, ISO/IEC 27002:2022 5.16, ISO/IEC 27002:2022 8.5

Quellen

[Q-OLLAMA-001] Local access; [Q-VLLM-001] Security und API server; [Q-OPENWEBUI-002] Authentication und API endpoints; [Q-BSI-001] S. 12¹²

¹² Ollama: Authentication, Online-Dokumentation, Abrufstand 02.09.2026, Local access, <https://docs.ollama.com/api/authentication>, abgerufen am 02.09.2026. | vLLM Project: Security, Online-Dokumentation, Abrufstand 02.09.2026, Security und API server, <https://docs.vllm.ai/en/stable/usage/security/>, abgerufen am 02.09.2026. | Open WebUI: API Endpoints, Online-Dokumentation, Abrufstand 02.09.2026, Authentication und API endpoints, <https://docs.openwebui.com/reference/api-endpoints/>, abgerufen am 02.09.2026. | Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026.

KI-API-002 – Serverseitige Modell-, Kontext-, Raten- und Toolgrenzen

Normative Anforderung

Der kontrollierte KI-Zugang MUSS pro Rolle und Anwendungsfall freigegebene Modelle, maximale Kontext- und Ausgabegrößen, Raten- und Parallelitätsgrenzen sowie zulässige Tool-Fähigkeiten serverseitig erzwingen. Clientseitige Einstellungen allein sind unzureichend.

Begründung

Manipulierte oder fehlerhaft konfigurierte Clients können sonst nicht freigegebene Modelle, übermäßige Ressourcen oder privilegierte Funktionen anfordern.

Umsetzung in der Referenzarchitektur

Richtlinien werden zentral versioniert, getestet und protokolliert. Nicht bekannte Modelle, Parameter, Endpunkte und Fähigkeiten werden abgewiesen.

Prüfziel

Versuchen, Grenzen über alternative Clients, manipulierte Parameter und direkte Endpunkte zu umgehen; jeder Versuch muss verhindert und nachvollziehbar protokolliert werden.

Erwartete Nachweise

Gateway-Richtlinien; Modellfreigabeliste; Grenzwertkatalog; negative Umgehungstests; Ratenbegrenzungs- und Alarmanzeige.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Einführung; Betrieb; Änderung; Gateway-Verantwortliche; KI-Verantwortliche; Fachverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: APP.6, DER.1; ISO: ISO/IEC 27002:2022 8.26, ISO/IEC 27002:2022 8.28

Quellen

[Q-BSI-001] S. 11–16; [Q-VLLM-001] Security und API server; [Q-OWASP-001] übermäßige Handlungsfreiheit und Ressourcenverbrauch¹³

¹³ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 11–16, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | vLLM Project: Security, Online-Dokumentation, Abrufstand 02.09.2026, Security und API server, <https://docs.vllm.ai/en/stable/usage/security/>, abgerufen am 02.09.2026. | OWASP Foundation: OWASP Top 10 for Large Language Model Applications, Ausgabe 2025, Abrufstand 02.09.2026, übermäßige Handlungsfreiheit und Ressourcenverbrauch, <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, abgerufen am 02.09.2026.

9.6 Modellbeschaffung, Provenienz, Integrität und Austausch

KI-MOD-001 – Kontrollierter Modellimport und Provenienz

Normative Anforderung

Jedes Modell MUSS aus einer freigegebenen Quelle über einen kontrollierten Offline-Import übernommen werden. Herkunft, Lizenz, Modellkarte, Format, Version, kryptografischer Hash, verfügbare Signatur, Scannergebnisse und Freigabeentscheidung MÜSSEN dokumentiert werden; unsichere serialisierte Formate DÜRFEN nicht ungeprüft geladen werden.

Begründung

Modelle sind ausführbare beziehungsweise interpretierte Lieferkettenartefakte. Manipulierte Gewichte oder Formate können Fehlverhalten, Schadcode oder Datenabfluss ermöglichen.

Umsetzung in der Referenzarchitektur

Ein Vier-Augen-Importprozess lädt außerhalb der KI-Zone, prüft Hashes, Signaturen, Dateiformat, Malware und Herkunft und veröffentlicht nur freigegebene, unveränderbare Artefakte in einer lokalen Modellregistrierung.

Prüfziel

Für jedes aktive Modell die vollständige Kette von öffentlicher Herkunft bis zum tatsächlich geladenen Hash nachvollziehen und manipulierte Testartefakte abweisen.

Erwartete Nachweise

Modellakte; Hash- und Signaturnachweise; Lizenzprüfung; Importprotokoll; Scannergebnis; lokale Registrierungsdaten; negativer Manipulationstest.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Beschaffung; Import; Freigabe; Modellverantwortliche; Informationssicherheitsbeauftragte; Beschaffung
Orientierende Zuordnung	BSI/IT-Grundschutz: OPS.1.1.10, OPS.1.1.6; ISO: ISO/IEC 27002:2022 5.21, ISO/IEC 27002:2022 8.19

Quellen

[Q-BSI-001] S. 9–10; [Q-NCSC-001] Secure development und deployment; [Q-OWASP-001] Lieferkettenrisiken¹⁴

¹⁴ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 9–10, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | UK National Cyber Security Centre und internationale Partner: Guidelines for Secure AI System Development, Version 1.0, 2023-11-26, Secure development und deployment, <https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development/about-this-document>, abgerufen am 02.09.2026. | OWASP Foundation: OWASP Top 10 for Large Language Model Applications, Ausgabe 2025, Abrufstand 02.09.2026, Lieferkettenrisiken, <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, abgerufen am 02.09.2026.

KI-MOD-002 – Versionierte Modellfreigabe und Rückrollbarkeit

Normative Anforderung

Modellfreigaben MÜSSEN einen unveränderbaren Modellhash, Laufzeitversion, Quantisierung, Systemanweisungen, Sicherheitsparameter, Evaluationsstand und genehmigte Anwendungsfälle binden. Austausch, Rücknahme und Rollback MÜSSEN ohne Veränderung von Fachwissen im Modell möglich und erprobt sein.

Begründung

Gleich benannte Modelle oder geänderte Laufzeiten können abweichendes Verhalten zeigen. Die Trennung des Fachwissens über RAG ermöglicht kontrollierten Austausch.

Umsetzung in der Referenzarchitektur

Freigabemanifeste verwenden unveränderbare Kennungen. Vorherige geprüfte Kombinationen bleiben innerhalb der Aufbewahrungsfrist lokal verfügbar; Abhängigkeiten und RAG-Kompatibilität werden geprüft.

Prüfziel

Eine freigegebene Version eindeutig reproduzieren, einen Modellwechsel mit Regression prüfen und auf eine vorherige Kombination zurückrollen.

Erwartete Nachweise

Freigabemanifest; Modell- und Laufzeithashes; Evaluationsbericht; Änderungsfreigabe; dokumentierter Rollbacktest; RAG-Kompatibilitätsnachweis.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Freigabe; Änderung; Betrieb; Modellverantwortliche; Testverantwortliche; Änderungsverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschatz: OPS.1.1.3, OPS.1.1.6; ISO: ISO/IEC 42001:2023 A.6, ISO/IEC 5338:2023

Quellen

[Q-BSI-001] S. 9–12; [Q-BMVG-001] S. 25–32; [Q-ISO-5338] öffentliche Metadaten zum KI-Systemlebenszyklus¹⁵

¹⁵ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 9–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, 2026-08-04, S. 25–32, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | International Organization for Standardization / International Electrotechnical Commission: Information technology — Artificial intelligence — AI system life cycle processes, ISO/IEC 5338:2023, 2023-12-01, öffentliche Metadaten zum KI-Systemlebenszyklus, <https://www.iso.org/standard/81118.html>, abgerufen am 02.09.2026.

9.7 Ausdrückliches Trainings- und Feinabstimmungsverbot

KI-TRN-001 – Keine Änderung von Modellgewichten

Normative Anforderung

Vortraining, Fine-Tuning, LoRA, PEFT, RLHF, kontinuierliches oder selbsttätiges Lernen sowie Training aus Chats, Uploads, RAG-Dokumenten oder Nutzereingaben DÜRFEN innerhalb dieses Geltungsberichts nicht stattfinden. Produktive Modellgewichte MÜSSEN unveränderbar sein.

Begründung

Training eröffnet eigenständige Risiken für Datenrecht, Datenqualität, Modellintegrität, Reproduzierbarkeit und Freigabe. Die Referenz hält Basismodelle austauschbar und Fachwissen außerhalb der Gewichte.

Umsetzung in der Referenzarchitektur

Trainingsframeworks, Schreibpfade auf Modellgewichte und lernende Rückkopplungen werden nicht bereitgestellt. Embedding-Erzeugung, RAG-Indexierung, Systemanweisungen und temporärer Kontext werden technisch und dokumentarisch klar abgegrenzt.

Prüfziel

Prüfen, dass Architektur, Pakete, Rechte, Jobs und Speicherpfade keine Gewichtsänderung erlauben und Nutzungsdaten nicht als Trainingsdaten exportiert werden.

Erwartete Nachweise

Software- und Jobinventar; schreibgeschützte Modellablage; Dateintegritätsmessung; Datenflussprüfung; negative Trainingstests; Freigaberegulierung.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Gesamter-Lebenszyklus; KI-Verantwortliche; Plattformverantwortliche; Datenverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschrift: APP.6, OPS.1.1.3; ISO: ISO/IEC 42001:2023 A.6, ISO/IEC 5338:2023

Quellen

[Q-BSI-001] S. 5 zur Abgrenzung von Modellentwicklung und Fine-Tuning; [Q-BMVG-001] S. 25–32 zum kontrollierten Lebenszyklus; [Q-ISO-5338] öffentliche Lebenszyklusmetadaten¹⁶

¹⁶ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 5 zur Abgrenzung von Modellentwicklung und Fine-Tuning, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, 2026-08-04, S. 25–32 zum kontrollierten Lebenszyklus, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | International Organization for Standardization / International Electrotechnical Commission: Information technology — Artificial intelligence — AI system life cycle processes, ISO/IEC 5338:2023, 2023-12-01, öffentliche Lebenszyklusmetadaten, <https://www.iso.org/standard/81118.html>, abgerufen am 02.09.2026.

9.8 Lokale RAG-, Embedding- und Upload-Sicherheit

KI-RAG-001 – Kontrollierte Aufnahme und isolierte Dokumentenaufbereitung

Normative Anforderung

RAG-Dokumente und Uploads MÜSSEN vor Verarbeitung auf zulässigen Dateityp, Größe, Schadsoftware und aktive Inhalte geprüft werden. Parser, Konverter und Extraktoren MÜSSEN isoliert mit minimalen Rechten, ohne Internet-Egress und mit begrenzten Ressourcen arbeiten.

Begründung

Dokumente sind eine untrusted Eingabe und können Parserlücken, aktive Inhalte, Ressourcenangriffe oder indirekte Prompt Injection enthalten.

Umsetzung in der Referenzarchitektur

Eine Quarantäne nimmt Dateien entgegen, validiert Signatur und tatsächlichen Typ, scannt sie und übergibt nur zulässige Inhalte an kurzlebige isolierte Parser. Fehlerhafte oder mehrdeutige Dateien werden abgewiesen.

Prüfziel

Mit präparierten Dateien prüfen, ob Typumgehung, aktive Inhalte, Malware, Parserabstürze und Ressourcenüberschreitungen sicher behandelt werden.

Erwartete Nachweise

Uploadrichtlinie; Parser-Sicherheitsprofil; Malware- und Typprüfprotokolle; Ressourcenlimits; negative Testkorpora; Quarantäne- und Löschprotokolle.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Aufnahme; Betrieb; RAG-Verantwortliche; Plattformverantwortliche; Informationssicherheitsbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: APP.6, SYS.1.6; ISO: ISO/IEC 27002:2022 8.7, ISO/IEC 27002:2022 8.26

Quellen

[Q-DSK-003] Kap. 2–5; [Q-DSK-002] Kap. 2–6; [Q-OWASP-001] Prompt Injection und Ressourcenverbrauch¹⁷

¹⁷ Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu datenschutzrechtlichen Besonderheiten generativer KI-Systeme mit RAG-Methode, Version 1.0, 2025-10-17, Kap. 2–5, https://www.datenschutzkonferenz-online.de/media/oh/DSK_OH_RAG.pdf, abgerufen am 02.09.2026. | Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu empfohlenen technischen und organisatorischen Maßnahmen bei der Entwicklung und beim Betrieb von KI-Systemen, Version 1.0, 2025-06-17, Kap. 2–6, https://www.datenschutzkonferenz-online.de/media/oh/DSK-OH_KI-Systeme.pdf, abgerufen am 02.09.2026. | OWASP Foundation: OWASP Top 10 for Large Language Model Applications, Ausgabe 2025, Abrufstand 02.09.2026, Prompt Injection und Ressourcenverbrauch, <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, abgerufen am 02.09.2026.

KI-RAG-002 – Durchgängige Berechtigungsprüfung und Indextrennung

Normative Anforderung

Vor Aufnahme eines Dokuments und bei jeder Abfrage MUSS die Berechtigung anhand einer autoritativen lokalen Quelle geprüft werden. Zugriffsentscheidungen DÜRFEN weder Systemanweisungen noch dem Sprachmodell überlassen werden. Index, Metadaten, Suche, Cache und Ausgabe MÜSSEN dieselbe Berechtigungstrennung wahren.

Begründung

Ein globaler Vektorindex oder nur promptbasierte Filter kann geschützte Textausschnitte über semantische Suche, Cache oder Modellausgabe offenlegen.

Umsetzung in der Referenzarchitektur

Dokumente tragen Herkunft, Eigentümer, Schutzbedarf und ACL-Metadaten. Die Suchschicht filtert vor Retrieval serverseitig mit aktueller Nutzeridentität; Änderungen und Widerrufe werden zeitnah propagiert.

Prüfziel

Mit berechtigten und unberechtigten Testidentitäten belegen, dass Aufnahme, Suche, direkte Objektanfrage, Cache und generierte Antwort keine ACL-Grenze überschreiten.

Erwartete Nachweise

ACL- und Identitätsmapping; Indexschema; Filterkonfiguration; Widerrufslatenz; positive und negative Berechtigungstests; Cachetests.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Aufnahme; Abfrage; Änderung; Datenverantwortliche; RAG-Verantwortliche; Identitätsverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: ORP.4, APP.6; ISO: ISO/IEC 27002:2022 5.15, ISO/IEC 27002:2022 8.3

Quellen

[Q-DSK-003] Kap. 2–5; [Q-BSI-001] S. 11–12; [Q-BFDI-001] Kap. 3–7¹⁸

¹⁸ Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu datenschutzrechtlichen Besonderheiten generativer KI-Systeme mit RAG-Methode, Version 1.0, 2025-10-17, Kap. 2–5, https://www.datenschutzkonferenz-online.de/media/oh/DSK_OH_RAG.pdf, abgerufen am 02.09.2026. | Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 11–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Die Bundesbeauftragte für den Datenschutz und die Informationsfreiheit: KI in Behörden – Datenschutz von Anfang an mitdenken, Handreichung für die Bundesverwaltung, 2025-12-22, Kap. 3–7, https://www.bfdi.bund.de/SharedDocs/Downloads/DE/DokumenteBfDI/Dokumente-allg/2025/Handreichung-KI.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026.

KI-RAG-003 – Schutz, Nachvollziehbarkeit und vollständige Löschung abgeleiteter Daten

Normative Anforderung

Embeddings, Chunks, Indizes, Reranking-Daten und Caches MÜSSEN mindestens wie die Quelldaten geschützt werden. Herkunft und konkrete Fundstellen MÜSSEN bis zur Ausgabe nachvollziehbar bleiben. Löschung MUSS Quelldatei, Extrakte, Index, Embeddings, Cache und den geregelten Ablauf in Sicherungsketten erfassen.

Begründung

Abgeleitete Repräsentationen können Inhalte, Personenbezug und Schutzbedarf bewahren. Unvollständige Löschung oder fehlende Provenienz verhindert Betroffenenrechte und fachliche Prüfung.

Umsetzung in der Referenzarchitektur

Stabile Dokument- und Chunk-IDs verbinden Quelle, Version, ACL und Aufbewahrung. Ein Löschauftrag erzeugt überprüfbare Tombstones, entfernt Onlinekopien und steuert das Auslaufen aus Sicherungen.

Prüfziel

Für eine Testquelle Herkunft bis zur Antwort nachweisen und anschließend die Nichtauffindbarkeit in sämtlichen Onlineebenen sowie geregelte Sicherungsbehandlung bestätigen.

Erwartete Nachweise

Datenkatalog; Provenienzymetadaten; Quellennachweise in Ausgaben; Aufbewahrungsplan; Löschkprotokoll; Such- und Cache-Nachtest; Sicherungskonzept.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Aufnahme; Nutzung; Löschung; Datenverantwortliche; RAG-Verantwortliche; Backup-Verantwortliche; Datenschutzbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: CON.6, CON.3; ISO: ISO/IEC 27002:2022 8.10, ISO/IEC 27002:2022 8.13, ISO/IEC 5259-1:2024

Quellen

[Q-DSK-003] Kap. 2–5; [Q-DSK-002] Kap. 2–6; [Q-BFDI-001] Kap. 4–7¹⁹

¹⁹ Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu datenschutzrechtlichen Besonderheiten generativer KI-Systeme mit RAG-Methode, Version 1.0, 2025-10-17, Kap. 2–5, https://www.datenschutzkonferenz-online.de/media/oh/DSK_OH_RAG.pdf, abgerufen am 02.09.2026. | Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu empfohlenen technischen und organisatorischen Maßnahmen bei der Entwicklung und beim Betrieb von KI-Systemen, Version 1.0, 2025-06-17, Kap. 2–6, https://www.datenschutzkonferenz-online.de/media/oh/DSK-OH_KI-Systeme.pdf, abgerufen am 02.09.2026. | Die Bundesbeauftragte für den Datenschutz und die Informationsfreiheit: KI in Behörden – Datenschutz von Anfang an mitdenken, Handreichung für die Bundesverwaltung, 2025-12-22, Kap. 4–7, https://www.bfdi.bund.de/SharedDocs/Downloads/DE/DokumenteBfDI/Dokumente-allg/2025/Handreichung-KI.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026.

KI-RAG-004 – Sitzungsbezogene On-Demand-Uploads

Normative Anforderung

On-Demand-Uploads MÜSSEN standardmäßig sitzungsbezogen, zweckgebunden und zeitlich begrenzt verarbeitet werden. Eine persistente Ablage oder Aufnahme in einen dauerhaften RAG-Bestand DARF nur nach ausdrücklicher Genehmigung, Metadatenvergabe und Berechtigungsprüfung erfolgen.

Begründung

Beiläufige Uploads können unbemerkt zu dauerhaften Wissens- oder Protokollbeständen werden und Zweckbindung, Löschung sowie Zugriffsschutz unterlaufen.

Umsetzung in der Referenzarchitektur

Temporäre Speicher verwenden eindeutige Sitzungs- und Nutzerbindung, kurze Aufbewahrung, keine globale Suche und einen verifizierten Abschlusslöschlauf. UI und API zeigen die Speicherwirkung vor Upload an.

Prüfziel

Nach Sitzungsende prüfen, dass Upload, Extrakte, Embeddings und Caches nicht mehr zugreifbar sind und keine Aufnahme in dauerhafte Indizes erfolgte.

Erwartete Nachweise

Uploadanzeige; Aufbewahrungskonfiguration; Sitzungsbindung; Löschjobprotokolle; negative Suchtests; Genehmigung für persistente Ausnahmen.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Nutzung; Löschung; Nutzende; RAG-Verantwortliche; Datenschutzbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: CON.6, APP.6; ISO: ISO/IEC 27002:2022 8.10, ISO/IEC 27002:2022 8.12

Quellen

[Q-DSK-003] Kap. 2–5; [Q-BMI-001] S. 25–29²⁰

²⁰ Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu datenschutzrechtlichen Besonderheiten generativer KI-Systeme mit RAG-Methode, Version 1.0, 2025-10-17, Kap. 2–5, https://www.datenschutzkonferenz-online.de/media/oh/DSK_OH_RAG.pdf, abgerufen am 02.09.2026. | Bundesministerium des Innern und für Heimat / Beratungszentrum für Künstliche Intelligenz: Leitlinien für den Einsatz Künstlicher Intelligenz in der Bundesverwaltung, Erstfassung, 2025-04-07, S. 25–29, <https://www.bmi.bund.de/SharedDocs/downloads/DE/publikationen/themen/moderne-verwaltung/ki/BMI25020-leitlinien-ki-bundesverwaltung.html>, abgerufen am 02.09.2026.

9.9 Identitäten, Rollen, technische Konten und Geheimnisse

KI-IAM-001 – Least Privilege und Geheimnisbehandlung für KI-Dienste

Normative Anforderung

Nutzer-, Dienst- und Administrationsidentitäten MÜSSEN getrennt, minimal berechtigt, einzeln widerrufbar und einer verantwortlichen Stelle zugeordnet sein. Geheimnisse DÜRFEN nicht in Prompts, Projektdaten, Images, Modellartefakten, Chatverläufen oder Protokollen gespeichert werden.

Begründung

Agentische Werkzeuge und KI-Dienste verbinden Dateisysteme, APIs und Entwicklungswerkzeuge; ein gemeinsames Konto vergrößert Wirkung und erschwert Zurechnung.

Umsetzung in der Referenzarchitektur

Lokaler IdP, kurzlebige Anmeldedaten, verwalteter Secret Store, dienstbezogene Rollen, MFA für privilegierte Zugriffe und regelmäßige Rezertifizierung werden eingesetzt. Protokollfilter maskieren Geheimnismuster.

Prüfziel

Prüfen, ob effektive Rechte dem genehmigten Zweck entsprechen, Widerruf wirksam ist und Geheimnisse weder in typischen Eingabe- noch Ausgabepfaden erscheinen.

Erwartete Nachweise

Rollen- und Kontenregister; Rezertifizierung; Secret-Store-Konfiguration; Widerrufstest; Suchlauf in Repositories und Protokollen; Administrationsnachweise.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Einführung; Betrieb; Änderung; Identitätsverantwortliche; Plattformverantwortliche; Informationssicherheitsbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschatz: ORP.4, CON.7; ISO: ISO/IEC 27002:2022 5.15, ISO/IEC 27002:2022 5.16, ISO/IEC 27002:2022 8.2

Quellen

[Q-BSI-001] S. 8–13; [Q-BMI-001] S. 25–29; [Q-DSK-002] Kap. 2–6²¹

²¹ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 8–13, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium des Innern und für Heimat / Beratungszentrum für Künstliche Intelligenz: Leitlinien für den Einsatz Künstlicher Intelligenz in der Bundesverwaltung, Erstfassung, 2025-04-07, S. 25–29, <https://www.bmi.bund.de/SharedDocs/downloads/DE/publikationen/themen/moderne-verwaltung/ki/BMI25020-leitlinien-ki-bundesverwaltung.html>, abgerufen am 02.09.2026. | Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu empfohlenen technischen und organisatorischen Maßnahmen bei der Entwicklung und beim Betrieb von KI-Systemen, Version 1.0, 2025-06-17, Kap. 2–6, https://www.datenschutzkonferenz-online.de/media/oh/DSK-OH_KI-Systeme.pdf, abgerufen am 02.09.2026.

9.10 Chat-Oberflächen und agentische Clientanwendungen

KI-AGT-001 – Minimale lokale Arbeitsbereichs- und Dateirechte

Normative Anforderung

Chat-Oberflächen und agentische Clients MÜSSEN auf genehmigte lokale Arbeitsbereiche und die minimal erforderlichen Lese- beziehungsweise Schreibrechte begrenzt werden. Pauschale Administrator-, Benutzerprofil-, Laufwerks- oder Repository-Rechte DÜRFEN nicht erteilt werden.

Begründung

Agentische Anwendungen können Modellentscheidungen in reale Datei- und Entwicklungsoperationen übersetzen. Breite Rechte verwandeln Fehlanweisungen oder Prompt Injection in unmittelbare Schäden.

Umsetzung in der Referenzarchitektur

Arbeitsbereichsprofile trennen Lesen, Schreiben, Ausführen und Netz. Betriebssystemrechte, Sandbox oder gleichwertige Kontrollen verhindern Zugriffe außerhalb des ausgewählten Projekts.

Prüfziel

Mit Testdateien innerhalb und außerhalb des Arbeitsbereichs nachweisen, dass jede nicht genehmigte Lese-, Schreib- und Ausführungsoperation scheitert.

Erwartete Nachweise

Clientrichtlinie; effektive Dateirechte; Sandboxprofil; Rollenfreigabe; negative Pfad- und Privilegien-tests.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Einführung; Nutzung; Clientverantwortliche; Fachverantwortliche; Nutzende
Orientierende Zuordnung	BSI/IT-Grundschutz: ORP.4, APP.6; ISO: ISO/IEC 27002:2022 8.2, ISO/IEC 27002:2022 8.18

Quellen

[Q-BSI-001] S. 12–16; [Q-CLINE-001] Provider- und Endpunktconfiguration; [Q-OPENCODE-001] lokale Modelle und Provider²²

²² Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 12–16, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Cline Bot Inc.: Cline Model Providers, Commit 0b0ca9b1fa95ed9f3e0891a34f1f9b3904309710, 2026-05-12, Provider- und Endpunktconfiguration, <https://github.com/cline/cline/blob/0b0ca9b1fa95ed9f3e0891a34f1f9b3904309710/docs/sdk/model-providers.mdx>, abgerufen am 02.09.2026. | Anomaly Innovations Inc.: OpenCode Models, Version 2, Online-Dokumentation, Abrufstand 02.09.2026, lokale Modelle und Provider, <https://opencode.ai/v2/docs/models>, abgerufen am 02.09.2026.

KI-AGT-002 – Lokale und freigegebene Modellendpunkte

Normative Anforderung

Chat- und Agentenclients MÜSSEN ausschließlich auf freigegebene lokale HTTPS-Endpunkte festgelegt werden. Nutzende DÜRFEN keine beliebigen Provider, Basen-URLs oder Modelle hinzufügen; Telemetrie, automatische Anmeldung und Cloud-Fallbacks MÜSSEN deaktiviert sein.

Begründung

Kompatible Endpunktconfigurationen erleichtern den unbeabsichtigten Wechsel zu externen Diensten und umgehen zentrale Modellfreigaben.

Umsetzung in der Referenzarchitektur

Clientconfigurationen werden verwaltet, signiert oder gegen eine Baseline geprüft. Namensauflösung und Egress-Regeln bilden eine zweite technische Sperre.

Prüfziel

Manipulierte Clientconfigurationen und alternative Provider müssen blockiert oder erkannt werden; der wirksame Endpunkt ist serverseitig und im Netzprotokoll nachweisbar.

Erwartete Nachweise

Clientbaseline; Providerfreigabeliste; Konfigurationsschutz; Egress- und DNS-Protokolle; negative Provider- und Fallbacktests.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Einführung; Betrieb; Clientverantwortliche; Netzverantwortliche; KI-Verantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: APP.6, NET.1.1; ISO: ISO/IEC 27002:2022 8.19, ISO/IEC 27002:2022 8.20

Quellen

[Q-OPENWEBUI-001] OpenAI-kompatible Anbindung; [Q-CLINE-001] OpenAI-Compatible Providers; [Q-OPENCODE-001] Local models; [Q-LLAMACPP-001] llama-server-Verweise²³

²³ Open WebUI: Starting with OpenAI-compatible providers, Online-Dokumentation, Abrufstand 02.09.2026, OpenAI-kompatible Anbindung, <https://docs.openwebui.com/getting-started/quick-start/connect-a-provider/starting-with-openai-compatible/>, abgerufen am 02.09.2026. | Cline Bot Inc.: Cline Model Providers, Commit 0b0ca9b1fa95ed9f3e0891a34f1f9b3904309710, 2026-05-12, OpenAI-Compatible Providers, <https://github.com/cline/cline/blob/0b0ca9b1fa95ed9f3e0891a34f1f9b3904309710/docs/sdk/model-providers.mdx>, abgerufen am 02.09.2026. | Anomaly Innovations Inc.: OpenCode Models, Version 2, Online-Dokumentation, Abrufstand 02.09.2026, Local models, <https://opencode.ai/v2/docs/models>, abgerufen am 02.09.2026. | ggml-org: llama.cpp, Commit ccc8fd2baa64ab26c7210b02765d3604069ec7ee, 2026-08-23, llama-server-Verweise, <https://github.com/ggml-org/llama.cpp/tree/ccc8fd2baa64ab26c7210b02765d3604069ec7ee>, abgerufen am 02.09.2026.

9.11 Prompt Injection, Datenabfluss und unsichere Modellausgaben

KI-PMT-001 – Untrusted Inhalte und indirekte Prompt Injection

Normative Anforderung

Inhalte aus Dokumenten, Quellcode, Webseiten, Tool-Ausgaben und RAG-Treffern MÜSSEN als untrusted Daten behandelt und von Systemanweisungen getrennt werden. Sie DÜRFEN keine Berechtigungen erweitern, Sicherheitsrichtlinien verändern oder selbstständig Tool-Aktionen auslösen.

Begründung

Sprachmodelle unterscheiden Anweisungen und Daten nicht zuverlässig. Indirekte Prompt Injection kann über vertrauenswürdig erscheinende Quellen Aktionen oder Datenabfluss anstoßen.

Umsetzung in der Referenzarchitektur

Vertrauensmarkierungen, Kontexttrennung, Instruktionshierarchie, Tool-Policy, Ausgabevalidierung und Bestätigungsgates wirken gemeinsam. Quellen mit erkannten Manipulationsmustern werden isoliert oder verworfen.

Prüfziel

Mit dokumentierten direkten und indirekten Angriffsprompts prüfen, dass Richtlinien, Berechtigungen, Geheimnisse und Toolgrenzen nicht umgangen werden.

Erwartete Nachweise

Bedrohungskorpus; Prompt-Injection-Tests; Richtlinienkonfiguration; Angriffsergebnisse; Block- und Alarmprotokolle; akzeptierte Restgrenzen.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Entwurf; Test; Nutzung; Betrieb; KI-Verantwortliche; RAG-Verantwortliche; Testverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: APP.6, DER.1; ISO: ISO/IEC 27002:2022 8.26, ISO/IEC 27002:2022 8.28

Quellen

[Q-BSI-001] S. 11–16; [Q-OWASP-001] Prompt Injection; [Q-NIST-002] adversariale Angriffe und Abhilfen²⁴

²⁴ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 11–16, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | OWASP Foundation: OWASP Top 10 for Large Language Model Applications, Ausgabe 2025, Abrufstand 02.09.2026, Prompt Injection, <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, abgerufen am 02.09.2026. | National Institute of Standards and Technology: Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations, NIST AI 100-2 E2025, 2025-03-24, adversariale Angriffe und Abhilfen, <https://csrc.nist.gov/pubs/ai/100/2/e2025/final>, abgerufen am 02.09.2026.

KI-OUT-001 – Validierung, Kennzeichnung und menschliche Prüfung von Ausgaben

Normative Anforderung

KI-Ausgaben MÜSSEN als potenziell unzutreffend und untrusted behandelt, anwendungsbezogen validiert und vor sicherheitsrelevanter, rechtlicher oder fachlich wesentlicher Wirkung durch eine befugte Person geprüft werden. KI-Nutzung und Quellen MÜSSEN entsprechend Zweck und Rechtslage nachvollziehbar gekennzeichnet werden.

Begründung

Plausibel formulierte Fehlantworten, unsicherer Code oder eingebettete Anweisungen können automatisiert weiterverarbeitet und dadurch wirksam werden.

Umsetzung in der Referenzarchitektur

Struktur-, Typ-, Policy- und Sicherheitsprüfungen begrenzen maschinelle Weiterverarbeitung. Hochwirksame Entscheidungen und Änderungen besitzen ein echtes menschliches Stopprecht und nachvollziehbare Freigabe.

Prüfziel

Fehlerhafte, manipulative und formal ungültige Ausgaben einspeisen und nachweisen, dass keine unkontrollierte Folgewirkung eintritt.

Erwartete Nachweise

Validierungsregeln; Review- und Freigabeprotokolle; Kennzeichnungsvorgaben; Fehlerkorpus; negative Weiterverarbeitungstests.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Nutzung; Freigabe; Betrieb; Nutzende; Fachverantwortliche; Testverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: APP.6, OPS.1.1.6; ISO: ISO/IEC 42001:2023 A.8, ISO/IEC 25059:2023

Quellen

[Q-BMI-001] S. 29–30; [Q-BSI-001] S. 9 und S. 12–16; [Q-BMVG-001] S. 29–32²⁵

²⁵ Bundesministerium des Innern und für Heimat / Beratungszentrum für Künstliche Intelligenz: Leitlinien für den Einsatz Künstlicher Intelligenz in der Bundesverwaltung, Erstfassung, 2025-04-07, S. 29–30, <https://www.bmi.bund.de/SharedDocs/downloads/DE/publikationen/themen/moderne-verwaltung/ki/BMI25020-leitlinien-ki-bundesverwaltung.html>, abgerufen am 02.09.2026. | Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 9 und S. 12–16, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, 2026-08-04, S. 29–32, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026.

9.12 Tool-Nutzung, Dateizugriff und Befehlsausführung

KI-TOL-001 – Getrennte Tool-Fähigkeiten und Bestätigung kritischer Aktionen

Normative Anforderung

Lesen, Schreiben, Befehlsausführung und Netzwerkzugriff MÜSSEN als getrennte, standardmäßig deaktivierte Fähigkeiten freigegeben werden. Sicherheitskritische, destruktive, privilegierte oder externe Aktionen MÜSSEN vor Ausführung eine verständliche, konkrete Bestätigung einer befugten Person erfordern.

Begründung

Eine pauschale Agentenfreigabe kann Modellfehler oder manipulierte Inhalte unmittelbar in irreversible Systemänderungen übersetzen.

Umsetzung in der Referenzarchitektur

Eine server- oder clientseitig erzwungene Tool-Policy bindet Fähigkeiten an Rolle, Arbeitsbereich und Anwendungsfall. Bestätigungsdialoge zeigen exakten Befehl, Ziel, Auswirkung und Datenziel; Sammel freigaben sind unzulässig.

Prüfziel

Prüfen, ob jede Fähigkeitsgrenze unabhängig wirkt und kritische Testaktionen ohne konkrete Bestätigung nicht ausgeführt werden.

Erwartete Nachweise

Tool-Policy; Rollenmatrix; Bestätigungsprotokolle; Testbefehle; negative Rechte- und Umgehungstests.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Entwurf; Einführung; Nutzung; Tool-Verantwortliche; Clientverantwortliche; Nutzende
Orientierende Zuordnung	BSI/IT-Grundschutz: ORP.4, APP.6; ISO: ISO/IEC 27002:2022 8.2, ISO/IEC 27002:2022 8.18

Quellen

[Q-BSI-001] S. 12–16; [Q-OWASP-001] übermäßige Handlungsfreiheit und unsichere Ausgabe; [Q-NIST-001] Manage- und Measure-Aktionen²⁶

²⁶ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 12–16, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | OWASP Foundation: OWASP Top 10 for Large Language Model Applications, Ausgabe 2025, Abrufstand 02.09.2026, übermäßige Handlungsfreiheit und unsichere Ausgabe, <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, abgerufen am 02.09.2026. | National Institute of Standards and Technology: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, 2024-07-26, Manage- und Measure-Aktionen, <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>, abgerufen am 02.09.2026.

KI-TOL-002 – Kontrollierte Erweiterungen, MCP-Server und Tool-Protokollierung

Normative Anforderung

Plug-ins, Erweiterungen, MCP-Server, Tools und Paketquellen MÜSSEN inventarisiert, lokal bezogen, versionsfixiert, geprüft und ausdrücklich freigegeben werden. Tool-Aufrufe MÜSSEN mit Identität, Zweck, Parametern, Ziel, Ergebnisstatus und Bestätigungsentscheidung lokal nachvollziehbar protokolliert werden, ohne unnötige Inhalts- oder Geheimnisdaten zu speichern.

Begründung

Erweiterungen bilden eine dynamische Lieferkette und können zusätzliche Rechte oder Egresspfade einführen. Ohne Aufrufprotokolle bleiben reale Agentenwirkungen unklar.

Umsetzung in der Referenzarchitektur

Zulässigkeitslisten, lokale Registrierungen, Hashes und Signaturen begrenzen die Lieferkette. Die Protokollierung trennt technische Metadaten von schutzbedürftigen Inhalten und schützt vor nachträglicher Veränderung.

Prüfziel

Unfreigegebene Erweiterungen und Versionen müssen blockiert werden; für genehmigte Testaufrufe muss eine vollständige, datensparsame Nachweiskette entstehen.

Erwartete Nachweise

Erweiterungsinventar; Freigabe- und Importnachweise; Hashes; lokale Registrierungen; Tool-Auditprotokolle; Manipulationsschutz; negative Installationstests.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Beschaffung; Einführung; Nutzung; Betrieb; Tool-Verantwortliche; Informationssicherheitsbeauftragte; Protokollierungsverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: OPS.1.1.10, OPS.1.1.5; ISO: ISO/IEC 27002:2022 5.21, ISO/IEC 27002:2022 8.15

Quellen

[Q-BSI-001] S. 10–13; [Q-NCSC-001] Secure development, deployment und operation; [Q-OWASP-001] Lieferkettenrisiken²⁷

²⁷ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 10–13, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | UK National Cyber Security Centre und internationale Partner: Guidelines for Secure AI System Development, Version 1.0, 2023-11-26, Secure development, deployment und operation, <https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development/about-this-document>, abgerufen am 02.09.2026. | OWASP Foundation: OWASP Top 10 for Large Language Model Applications, Ausgabe 2025, Abrufstand 02.09.2026, Lieferkettenrisiken, <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, abgerufen am 02.09.2026.

9.13 Adversariale Angriffe, Modellmissbrauch und Ressourcenerschöpfung

KI-THR-001 – KI-spezifisches Bedrohungsmodell

Normative Anforderung

Für jeden Anwendungsfall MUSS ein aktuelles Bedrohungsmodell Eingabe-, Modell-, Daten-, RAG-, Tool-, Client-, Schnittstellen- und Lieferkettenpfade betrachten. Mindestens Prompt Injection, Poisoning, Evasion, Datenrekonstruktion, Modellmissbrauch, unsichere Ausgaben, Privilegienausweitung und Datenabfluss MÜSSEN bewertet werden.

Begründung

Klassische Systemmodelle erfassen die probabilistische Verarbeitung untrusted Inhalte und die Handlungsketten agentischer Systeme nicht vollständig.

Umsetzung in der Referenzarchitektur

Datenflussdiagramme markieren Vertrauensgrenzen, Autoren, Veränderungsmöglichkeiten, Aktionen und schutzbedürftige Werte. Angriffstechniken werden mit vorbeugenden, erkennenden und reaktiven Kontrollen verknüpft.

Prüfziel

Prüfen, ob jeder real mögliche Daten- und Aktionspfad modelliert, mit Szenarien getestet und einer verantworteten Behandlung zugeordnet ist.

Erwartete Nachweise

Bedrohungsmodell; Datenflussdiagramm; Angriffsszenarien; Kontrollzuordnung; Testergebnisse; akzeptierte Restrisiken.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Planung; Test; Änderung; Betrieb; Informationssicherheitsbeauftragte; KI-Verantwortliche; Testverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: DER.1, APP.6; ISO: ISO/IEC 27001:2022 6.1, ISO/IEC 23894:2023

Quellen

[Q-BSI-001] S. 12–16; [Q-NIST-002] Taxonomie der Angriffe und Abhilfen; [Q-MITRE-001] Tactics and techniques; [Q-OWASP-001] LLM Top 10 2025²⁸

²⁸ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 12–16, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | National Institute of Standards and Technology: Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations, NIST AI 100-2 E2025, 2025-03-24, Taxonomie der Angriffe und Abhilfen, <https://csrc.nist.gov/pubs/ai/100/2/e2025/final>, abgerufen am 02.09.2026. | The MITRE Corporation: MITRE ATLAS, Laufend gepflegte Wissensbasis, Abrufstand 02.09.2026, Tactics and techniques, <https://atlas.mitre.org/>, abgerufen am 02.09.2026. | OWASP Foundation: OWASP Top 10 for Large Language Model Applications, Ausgabe 2025, Abrufstand 02.09.2026, LLM Top 10 2025, <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, abgerufen am 02.09.2026.

KI-THR-002 – Ressourcen-, Missbrauchs- und Verfügbarkeitsgrenzen

Normative Anforderung

Token, Kontext, Ausgabe, Datei- und Batchgröße, Parallelität, Laufzeit, Speicher, Beschleuniger, Retrieval-Treffer und Tool-Aufrufe MÜSSEN je Identität und Dienst begrenzt werden. Missbrauch und Ressourcenerschöpfung MÜSSEN erkannt, gedrosselt und kontrolliert beendet werden.

Begründung

Lange Kontexte, rekursive Agentenschleifen und aufwendige Anfragen können lokale Kapazität erschöpfen und andere Dienste verdrängen.

Umsetzung in der Referenzarchitektur

Quoten, Timeouts, Queueing, Circuit Breaker, Prioritäten und Kapazitätsreserven werden zentral konfiguriert. Kritische Basisdienste bleiben von KI-Ressourcen entkoppelt.

Prüfziel

Last-, Grenzwert- und Missbrauchstests müssen faire Begrenzung, sichere Beendigung, Alarmierung und Wiederherstellung ohne Datenkorruption belegen.

Erwartete Nachweise

Kapazitätsmodell; Grenzwertkonfiguration; Lasttests; Alarmregeln; Drosselungsprotokolle; Wiederherstellungsnachweis.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Entwurf; Test; Betrieb; Kapazitätsverantwortliche; Plattformverantwortliche; Betriebsverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: OPS.1.1.1, DER.1; ISO: ISO/IEC 27002:2022 8.6, ISO/IEC 27002:2022 8.16

Quellen

[Q-BSI-001] S. 14–16; [Q-OWASP-001] Ressourcenverbrauch; [Q-NIST-001] Measure- und Manage-Aktionen²⁹

²⁹ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 14–16, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | OWASP Foundation: OWASP Top 10 for Large Language Model Applications, Ausgabe 2025, Abrufstand 02.09.2026, Ressourcenverbrauch, <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, abgerufen am 02.09.2026. | National Institute of Standards and Technology: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, 2024-07-26, Measure- und Manage-Aktionen, <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>, abgerufen am 02.09.2026.

9.14 Evaluierung, Freigabe, Regression und Rollback

KI-VAL-001 – Reproduzierbare Qualitäts- und Sicherheitsevaluierung

Normative Anforderung

Vor Erstfreigabe MUSS jede Modell-Laufzeit-Anwendungsfall-Kombination anhand repräsentativer, getrennt verwalteter Testfälle auf fachliche Qualität, Robustheit, Datenschutz und Sicherheit evaluiert werden. Schwellenwerte, Metriken, Datensätze, Zufallsparameter, Umgebung und Ergebnisse MÜSSEN dokumentiert und reproduzierbar sein.

Begründung

Allgemeine Benchmarks belegen weder Eignung noch Sicherheit im lokalen Anwendungsfall. Modellantworten sind variabel und benötigen wiederholbare Messung.

Umsetzung in der Referenzarchitektur

Ein fachliches Testset, Missbrauchs- und Red-Team-Fälle sowie klare Abnahmeschwellen werden vor dem Test festgelegt. Unabhängige qualifizierte Personen prüfen wesentliche Ergebnisse.

Prüfziel

Eine Stichprobe muss mit derselben Konfiguration reproduzierbar sein; unterschrittene Schwellenwerte müssen die Freigabe blockieren.

Erwartete Nachweise

Testplan; versionierte Testdaten; Metrikdefinitionen; Laufzeit- und Parameterstand; Roh- und Ergebnisdaten; unabhängiges Review; Freigabeentscheidung.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Test; Freigabe; Testverantwortliche; Fachverantwortliche; Informationssicherheitsbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: OPS.1.1.6, APP.6; ISO: ISO/IEC 42001:2023 A.7, ISO/IEC 25059:2023

Quellen

[Q-BSI-001] S. 9–12; [Q-BMVG-001] S. 29–32; [Q-NIST-001] Measure-Aktionen; [Q-ISO-25059] öffentliche Metadaten zum KI-Qualitätsmodell³⁰

³⁰ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 9–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, 2026-08-04, S. 29–32, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | National Institute of Standards and Technology: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, 2024-07-26, Measure-Aktionen, <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>, abgerufen am 02.09.2026. | International Organization for Standardization / International Electrotechnical Commission: Software engineering — SQuaRE — Quality model for AI systems, ISO/IEC 25059:2023, 2023-06-01, öffentliche Metadaten zum KI-Qualitätsmodell, <https://www.iso.org/standard/80655.html>, abgerufen am 02.09.2026.

KI-VAL-002 – Änderungsabhängige Regression, Wiederfreigabe und Rollback

Normative Anforderung

Änderungen an Modell, Quantisierung, Laufzeit, Systemanweisung, RAG-Daten oder -Logik, Embeddings, Reranker, Gateway, Tooling und Sicherheitsparametern MÜSSEN risikobasiert Regressionstests und eine Wiederfreigabe auslösen. Bei Abweichungen MUSS ein getesteter Rollback verfügbar sein.

Begründung

KI-Verhalten entsteht aus der gesamten Kette. Eine scheinbar kleine Komponentenänderung kann Qualität, Sicherheit oder Berechtigungswirkung verschieben.

Umsetzung in der Referenzarchitektur

Eine Änderungsmatrix ordnet Komponenten konkrete Tests zu. Automatisierte Vergleiche erkennen Sicherheits- und Qualitätsregressionen; Freigabemanifeste erlauben atomaren Wechsel und Rückkehr.

Prüfziel

Für jede Änderung die ausgelösten Tests, Entscheidung und erfolgreiche Rückkehr zur vorherigen freigegebenen Kombination nachweisen.

Erwartete Nachweise

Änderungsantrag; Auswirkungsanalyse; Regressionsergebnisse; neues Freigabemanifest; Rollbackplan und -test; Kommunikationsnachweis.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Änderung; Test; Freigabe; Änderungsverantwortliche; Testverantwortliche; Betriebsverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschatz: OPS.1.1.3, OPS.1.1.6; ISO: ISO/IEC 27002:2022 8.32, ISO/IEC 5338:2023

Quellen

[Q-BSI-001] S. 8 und S. 11–12; [Q-BMVG-001] S. 29–32 und S. 45–47; [Q-ISO-5338] öffentliche Lebenszyklusmetadaten³¹

³¹ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 8 und S. 11–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, 2026-08-04, S. 29–32 und S. 45–47, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | International Organization for Standardization / International Electrotechnical Commission: Information technology — Artificial intelligence — AI system life cycle processes, ISO/IEC 5338:2023, 2023-12-01, öffentliche Lebenszyklusmetadaten, <https://www.iso.org/standard/81118.html>, abgerufen am 02.09.2026.

9.15 Protokollierung, Monitoring, Drift, Vorfälle und Wiederanlauf

KI-OPS-001 – Datensparsame und manipulationsgeschützte KI-Protokollierung

Normative Anforderung

Sicherheitsrelevante KI-Ereignisse MÜSSEN lokal, zeitlich synchronisiert, identitätsbezogen und manipulationsgeschützt protokolliert werden. Erforderlich sind mindestens Modell- und Richtlinienversion, Zugriff, Tool-Aufruf, Freigabe, Blockierung, Grenzwertverletzung, Administrationsänderung und Vorfallbezug; Inhaltsdaten DÜRFEN nur zweckgebunden und minimiert gespeichert werden.

Begründung

Ohne technische Kontextdaten lassen sich Modellverhalten und Agentenwirkungen nicht untersuchen; vollständige Prompts können zugleich sensible Inhalte und Geheimnisse vervielfachen.

Umsetzung in der Referenzarchitektur

Ein Protokollierungskonzept trennt Sicherheitsmetadaten, optionale Inhaltsprotokolle und Auditdaten, definiert Zugriff, Aufbewahrung, Integrität, Löschung und lokale SIEM-Korrelation.

Prüfziel

Aus einem Testvorfall die verantwortliche Identität, wirksame Modell- und Richtlinienversion sowie Toolkette rekonstruieren, ohne unnötige Inhaltsdaten offenzulegen.

Erwartete Nachweise

Protokollierungskonzept; Beispieldatensätze; Zeit- und Integritätsnachweis; SIEM-Regeln; Zugriffs- und Löschprüfung; Rekonstruktionsübung.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Betrieb; Vorfall; Prüfung; Protokollierungsverantwortliche; Datenschutzbeauftragte; Informationssicherheitsbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: OPS.1.1.5, DER.1; ISO: ISO/IEC 27002:2022 8.15, ISO/IEC 27002:2022 8.17

Quellen

[Q-BSI-001] S. 12–13; [Q-BMVG-001] S. 23–26 und S. 45–47; [Q-DSK-002] Kap. 2–6³²

³² Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 12–13, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, 2026-08-04, S. 23–26 und S. 45–47, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu empfohlenen technischen und organisatorischen Maßnahmen bei der Entwicklung und beim Betrieb von KI-Systemen, Version 1.0, 2025-06-17, Kap. 2–6, https://www.datenschutzkonferenz-online.de/media/oh/DSK-OH_KI-Systeme.pdf, abgerufen am 02.09.2026.

KI-OPS-002 – Monitoring, Drift und KI-Vorfallbehandlung

Normative Anforderung

Qualität, Fehlerraten, Ablehnungen, Ressourcenverbrauch, Policy-Verstöße, Prompt-Injection-Indikatoren, RAG-Auffälligkeiten und Modell- beziehungsweise Konfigurationsdrift MÜSSEN risikoorientiert überwacht werden. KI-spezifische Vorfälle MÜSSEN in den allgemeinen Vorfallprozess integriert und mit Abschalt- und Rückrollmöglichkeiten behandelt werden.

Begründung

Verschlechterungen und Angriffe zeigen sich häufig zuerst in Ausgabe- oder Nutzungsmetriken und nicht in klassischen Hostalarmen.

Umsetzung in der Referenzarchitektur

Baseline, Schwellenwerte, Alarmwege, Triageleitfäden und sichere Degradationsmodi werden festgelegt. Vorfallsübungen umfassen Datenabfluss, vergiftete RAG-Quelle, kompromittiertes Modell und Agentenfehlaktion.

Prüfziel

Künstliche Abweichungen müssen erkannt, richtig priorisiert und bis zu Eindämmung, Beweissicherung, Wiederherstellung und Nachbereitung bearbeitet werden.

Erwartete Nachweise

Monitoringkonzept; Dashboards; Alarmregeln; Driftbericht; Vorfallleitfäden; Übungsprotokolle; Korrektur- und Rückrollnachweise.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Betrieb; Vorfall; Änderung; Betriebsverantwortliche; Informationssicherheitsbeauftragte; Vorfallverantwortliche; Modellverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: DER.1, DER.2.1; ISO: ISO/IEC 27002:2022 8.16, ISO/IEC 27002:2022 5.24

Quellen

[Q-BMVG-001] S. 31–32 und S. 45–47; [Q-BSI-001] S. 8 und S. 12–16; [Q-NIST-001] Measure- und Manage-Aktionen³³

³³ Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, 2026-08-04, S. 31–32 und S. 45–47, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 8 und S. 12–16, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | National Institute of Standards and Technology: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, 2024-07-26, Measure- und Manage-Aktionen, <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>, abgerufen am 02.09.2026.

KI-OPS-003 – Wiederanlauf und konsistente Sicherungen

Normative Anforderung

Wiederanlauf- und Sicherungsverfahren MÜSSEN die konsistente Kombination aus Modell, Laufzeit, Gatewayrichtlinien, Systemanweisungen, RAG-Quellen, Index, ACL-Metadaten, Konfiguration und Nachweisen berücksichtigen. Wiederherstellungen MÜSSEN regelmäßig ohne Internetzugang erprobt werden.

Begründung

Ein technisch gestarteter Dienst ist nicht betriebsfähig, wenn Modell, Index, Berechtigungen oder Freigabestand auseinanderfallen.

Umsetzung in der Referenzarchitektur

Versionierte Sicherungssätze und Wiederanlaufreihenfolge stellen Identitäten und Richtlinien vor Daten- und KI-Funktionen bereit. Nach Wiederherstellung erfolgen Integritäts-, Berechtigungs- und Regressionstests.

Prüfziel

Aus freigegebenen Sicherungen eine konsistente Umgebung wiederherstellen und Hashes, ACLs, Kernfunktionen sowie fehlenden Internetbedarf nachweisen.

Erwartete Nachweise

Sicherungsmatrix; Wiederanlaufplan; Offline-Wiederherstellungstest; Integritäts- und ACL-Prüfung; Wiederanlaufzeiten; Abweichungsbehandlung.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Betrieb; Notfall; Wiederanlauf; Backup-Verantwortliche; Betriebsverantwortliche; Informationssicherheitsbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: CON.3, DER.4; ISO: ISO/IEC 27002:2022 8.13, ISO/IEC 27002:2022 5.30

Quellen

[Q-BSI-001] S. 11–13; [Q-NCSC-001] Secure operation and maintenance; [Q-BMVG-001] S. 45–47³⁴

³⁴ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 11–13, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | UK National Cyber Security Centre und internationale Partner: Guidelines for Secure AI System Development, Version 1.0, 2023-11-26, Secure operation and maintenance, <https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development/about-this-document>, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, 2026-08-04, S. 45–47, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026.

9.16 Außerbetriebnahme und nachweisbare Löschung

KI-DEC-001 – Kontrollierte Außerbetriebnahme

Normative Anforderung

Bei Außerbetriebnahme eines Modells, Dienstes, RAG-Bestands, Tools oder Anwendungsfalls MÜSSEN Zugänge widerrufen, Endpunkte entfernt, Aufgaben beendet, Modelle und Daten nach Aufbewahrungsregeln gelöscht, lokale Registrierungen bereinigt und Nachweise revisionsgeeignet abgeschlossen werden.

Begründung

Verwaiste Endpunkte, Konten, Indizes, Caches oder Modellkopien bleiben sonst erreichbar und entziehen sich Patch-, Rechte- und Löschprozessen.

Umsetzung in der Referenzarchitektur

Eine objektbezogene Checkliste umfasst Identitäten, Zertifikate, Geheimnisse, Netze, Jobs, Speicher, Sicherungen, Protokolle, Lizenzen und abhängige Anwendungsfälle. Fachwissen bleibt in kontrollierten Quellen und wird nicht aus Modellgewichten migriert.

Prüfziel

Für eine Testaußerbetriebnahme nachweisen, dass keine aktive Erreichbarkeit oder unzulässige Datenkopie verbleibt und erforderliche Nachweise erhalten sind.

Erwartete Nachweise

Außerbetriebnahmeauftrag; Widerrufs- und Netztest; Löschprotokolle; Registerabgleich; Sicherungsbehandlung; Abschlussfreigabe.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Außerbetriebnahme; Löschung; Systemverantwortliche; Datenverantwortliche; Identitätsverantwortliche; Informationssicherheitsbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: CON.6, OPS.1.1.2; ISO: ISO/IEC 27002:2022 8.10, ISO/IEC 27002:2022 5.11

Quellen

[Q-BSI-001] S. 13; [Q-DSK-001] Beendigung; [Q-BMVG-001] S. 45–47³⁵

³⁵ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 13, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Künstliche Intelligenz und Datenschutz, Version 1.0, 2024-05-06, Beendigung, https://www.datenschutzkonferenz-online.de/media/oh/20240506_DSK_Orientierungshilfe_KI_und_Datenschutz.pdf, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, 2026-08-04, S. 45–47, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026.

9.17 Bedingte Anforderungen für externe Inferenz

KI-EXT-001 – Neue Bewertung vor externer Inferenz

Normative Anforderung

Wenn externe Inferenz aktiviert werden soll, MUSS vor jeder Datenübertragung eine neue organisationsspezifische Bewertung und Freigabe mindestens Datenschutz, Klassifikation, Verträge, Auftragsverarbeitung, Drittlandbezug, Anbieter und Lieferkette, Protokollierung, Löschung, Aufbewahrung, Verschlüsselung, Schlüsselverwaltung, Verfügbarkeit, Vorfälle und Ausstieg abdecken. Ohne abgeschlossene Freigabe DARF keine externe Inferenz erfolgen.

Begründung

Prompts, Systemanweisungen, Kontexte, RAG-Ausschnitte, Uploads, Metadaten und Ausgaben werden beim externen Betreiber verarbeitet; TLS beseitigt diese Verarbeitung nicht.

Umsetzung in der Referenzarchitektur

Die Aktivierung setzt den Projektstatus auf organisationsspezifisch, erweitert Systemgrenze und Datenflussmodell und aktiviert einen gesonderten Kontroll- und Vertragsnachweis. Zulässige Daten und Endpunkte werden technisch aufgelistet.

Prüfziel

Vor einer kontrollierten Testanfrage prüfen, ob sämtliche Gates erfüllt sind und nicht freigegebene Daten beziehungsweise Endpunkte blockiert werden.

Erwartete Nachweise

Neue Risiko- und Datenschutzbewertung; Datenflussmodell; Verträge; Anbieterprüfung; Schlüssel- und Löschkonzept; Freigabe; negative Datentests.

Steuermerkmal	Ausprägung
Anwendbarkeit	bedingt-externe-inferenz
Lebenszyklus und Rollen	Planung; Beschaffung; Freigabe; Betrieb; Leitung; Datenschutzbeauftragte; Informationssicherheitsbeauftragte; Rechtsstelle; Beschaffung
Orientierende Zuordnung	BSI/IT-Grundschutz: OPS.2.2, CON.2; ISO: ISO/IEC 27002:2022 5.19, ISO/IEC 27002:2022 5.20, ISO/IEC 42001:2023 A.10

Quellen

[Q-BMI-001] S. 25–29; [Q-BSI-001] S. 4–5 und S. 9–12; [Q-BFDI-001] Kap. 1–7; [Q-EU-001] Art. 26–27³⁶

³⁶ Bundesministerium des Innern und für Heimat / Beratungszentrum für Künstliche Intelligenz: Leitlinien für den Einsatz Künstlicher Intelligenz in der Bundesverwaltung, Erstfassung, 2025-04-07, S. 25–29, <https://www.bmi.bund.de/SharedDocs/downloads/DE/publikationen/themen/moderne-verwaltung/ki/BMI25020-leitlinien-ki-bundesverwaltung.html>, abgerufen am 02.09.2026. | Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 4–5 und S. 9–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Die Bundesbeauftragte für den Datenschutz und die Informationsfreiheit: KI in Behörden – Datenschutz von Anfang an mitdenken, Handreichung für die Bundesverwaltung, 2025-12-22, Kap. 1–7, <https://www.bfdi.bund.de/SharedDocs/Downloads/DE/DokumenteBfDI/Dokumente->

KI-EXT-002 – Kein automatischer externer Fallback

Normative Anforderung

Cloud-Modelle, automatische Provider-Erkennung, externe Telemetrie und Fallbacks auf externe Endpunkte MÜSSEN standardmäßig deaktiviert sein. Eine aktivierte externe Variante MUSS jeden zulässigen Betreiber, Endpunkt, Modell- und Datenumfang ausdrücklich festlegen; nicht bekannte Ziele MÜSSEN technisch blockiert werden.

Begründung

Automatische Fallbacks können bei Fehlern oder Kapazitätsengpässen gerade dann Daten extern übertragen, wenn reguläre Kontrollen nicht aufmerksam beobachtet werden.

Umsetzung in der Referenzarchitektur

Client- und Gatewaykonfiguration, DNS, Proxy und Firewall verwenden positive Zulässigkeitslisten. Tests erzwingen Ausfall lokaler Modelle und bestätigen, dass keine externe Ersatzverbindung entsteht.

Prüfziel

Bei Ausfall, Fehlkonfiguration und manipulierten Providerangaben darf kein nicht freigegebener externer Datenfluss entstehen.

Erwartete Nachweise

Provider- und Endpunktliste; Egress-Regeln; Clientbaseline; Ausfall- und Fallbacktests; DNS-/Proxyprotokolle; Alarmnachweis.

Steuermerkmal	Ausprägung
Anwendbarkeit	bedingt-externe-inferenz
Lebenszyklus und Rollen	Einführung; Test; Betrieb; Clientverantwortliche; Gateway-Verantwortliche; Netzverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: NET.1.1, APP.6; ISO: ISO/IEC 27002:2022 8.20, ISO/IEC 27002:2022 8.26

Quellen

[Q-CLINE-001] Providerkonfiguration; [Q-OPENCODE-001] Provider und lokale Modelle; [Q-BSI-001] S. 9–12³⁷

allg/2025/Handreichung-KI.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Europäische Union: Verordnung (EU) 2024/1689 über künstliche Intelligenz, ABl. L 2024/1689, 2024-07-12, Art. 26–27, <https://eur-lex.europa.eu/eli/reg/2024/1689/oj>, abgerufen am 02.09.2026.

³⁷ Cline Bot Inc.: Cline Model Providers, Commit 0b0ca9b1fa95ed9f3e0891a34f1f9b3904309710, 2026-05-12, Providerkonfiguration, <https://github.com/cline/cline/blob/0b0ca9b1fa95ed9f3e0891a34f1f9b3904309710/docs/sdk/model-providers.mdx>, abgerufen am 02.09.2026. | Anomaly Innovations Inc.: OpenCode Models, Version 2, Online-Dokumentation, Abrufstand 02.09.2026, Provider und lokale Modelle, <https://opencode.ai/v2/docs/models>, abgerufen am 02.09.2026. | Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 9–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026.

9.18 Evidenz, Ausnahmen und akzeptierte Restrisiken

KI-ASS-001 – Prüfbare Nachweiskette und befristete Abweichungen

Normative Anforderung

Für jede anwendbare Kontrolle MÜSSEN verantwortliche Rolle, Umsetzungsstatus, prüfbarer Nachweis, Prüfdatum, Ergebnis und nächste Prüfung geführt werden. Abweichungen MÜSSEN Risiko, kompensierende Maßnahmen, Befristung, Genehmigende und Ausstiegskriterium enthalten; akzeptierte Restrisiken DÜRFEN nicht als erfüllte Kontrolle dargestellt werden.

Begründung

Eine dokumentierte Anforderung ist ohne aktuellen Wirksamkeitsnachweis nicht auditierbar. Unklare Ausnahmen können dauerhaft und unsichtbar werden.

Umsetzung in der Referenzarchitektur

Ein kontrolliertes Nachweisregister referenziert unveränderbare Artefakte und trennt Entwurf, umgesetzt, geprüft, abweichend und nicht anwendbar. Zugriff und Aufbewahrung richten sich nach dem Nachweisschutzbedarf.

Prüfziel

Für eine Stichprobe die lückenlose Kette von Kontroll-ID über Umsetzung und Prüfung bis zu Abweichung oder Freigabe nachvollziehen.

Erwartete Nachweise

Nachweisregister; Prüfprotokolle; Artefakthashes; Ausnahme- und Restrisikoregister; Genehmigungen; Wiedervorlagen; Abschlusskriterien.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Gesamter-Lebenszyklus; Kontrollverantwortliche; Prüfende; Risikoverantwortliche; Leitung
Orientierende Zuordnung	BSI/IT-Grundschutz: ISMS.1, DER.3.1; ISO: ISO/IEC 27001:2022 7.5, ISO/IEC 27001:2022 9.1, ISO/IEC 42001:2023 9.1

Quellen

[Q-BSI-001] S. 8–13; [Q-BMVG-001] S. 25–32 und S. 45–47; [Q-NIST-001] Govern-, Measure- und Manage-Aktionen³⁸

³⁸ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 8–13, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, 2026-08-04, S. 25–32 und S. 45–47, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | National Institute of Standards and Technology: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, 2024-07-26, Govern-, Measure- und Manage-Aktionen, <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>, abgerufen am 02.09.2026.

10 RAG-, Upload- und Datenkonzept

Domänenwissen verbleibt außerhalb der Modellgewichte. Lokale RAG-Bestände und lokale On-Demand-Uploads bilden die einzigen vorgesehenen Zuführungswege. KI-RAG-001 bis KI-RAG-004 fordern eine Quarantäne und isolierte Parser, Herkunfts- und Klassifikationsmetadaten, Berechtigungsprüfung vor Aufnahme und erneut bei jeder Abfrage, durchgängige ACL-Trennung sowie vollständige Aufbewahrungs- und Löschsteuerung.

- Embeddings, Chunks, Indizes, Caches und Reranking-Daten erhalten mindestens den Schutzbedarf der Quelldaten.
- Das Sprachmodell und Systemanweisungen treffen keine Zugriffsentscheidung.
- On-Demand-Uploads bleiben ohne ausdrückliche persistente Freigabe sitzungsbezogen.
- Ausgaben weisen verwendete Quellen und konkrete Fundstellen nachvollziehbar aus.
- Löschung umfasst Onlinekopien, Ableitungen, Caches und den geregelten Ablauf in Sicherungsketten.

KI-TRN-001 stellt klar, dass Indexierung und Embedding-Erzeugung keine Freigabe für Training, Feinabstimmung oder Änderungen von Modellgewichten sind.

11 Agentische Anwendungen und lokale Entwicklungsumgebungen

Agentische Clients wie Cline- oder OpenCode-artige Werkzeuge sind Produktbeispiele. Sie greifen ausschließlich über den lokalen HTTPS-Zugang auf freigegebene Modelle zu. Lokale Git-, Paket- und Entwicklungsdienste bleiben in der Organisationsumgebung.

- Arbeitsbereichs- und Dateirechte sind minimal und überschreiten weder Projekt noch genehmigten Zweck.
- Lesen, Schreiben, Befehlsausführung und Netzwerkzugriff sind getrennte Fähigkeiten.
- Kritische, destruktive, privilegierte oder externe Aktionen benötigen eine konkrete menschliche Bestätigung.
- Indirekte Prompt Injection aus Quellcode, Dokumenten, Webseiten und Tool-Ausgaben darf keine Rechte erweitern.
- Plug-ins, MCP-Server, Erweiterungen und Pakete stammen aus kontrollierten lokalen Quellen und sind versionsfixiert.
- Tool-Aufrufe werden identitätsbezogen, nachvollziehbar und datensparsam lokal protokolliert.

12 Betrieb, Änderung, Modellwechsel, Vorfälle und Außerbetriebnahme

Der Betrieb verbindet Freigabemanifest, lokale Protokollierung, SIEM-Auswertung, Qualitäts- und Sicherheitsmetriken, Driftbeobachtung, Kapazitätsgrenzen und den allgemeinen Vorfallprozess. Eine laufende Komponente allein belegt weder Berechtigung, Qualität, Datenlöschung noch Wiederherstellbarkeit.

Jede Änderung an Modell, Quantisierung, Laufzeit, Systemanweisung, RAG, Embedding, Reranker, Gateway, Tool oder Sicherheitsparameter löst eine risikobasierte Regression und Wiederfreigabe aus. Vorherige geprüfte Kombinationen bleiben kontrolliert rückrollbar. Wiederanlaufprüfungen erfolgen ohne Internetzugang und umfassen Hashes, Richtlinien, ACLs und Kernevaluation.

Bei Außerbetriebnahme werden Identitäten, Zertifikate, Geheimnisse, Endpunkte, Jobs, Modelle, Daten, Indizes und Caches behandelt. Erforderliche Auditnachweise bleiben entsprechend Aufbewahrung erhalten; unzulässige Restkopien und Erreichbarkeit müssen durch Nachtests ausgeschlossen werden.

13 Nachweis-, Prüf- und Mappingübersicht

Die Übersicht dient der Prüfplanung. Der vollständige Wortlaut, die Quellenlinks und sämtliche Eigenschaften verbleiben im OSCAL-Katalog.

Kontrolle	Titel	Anwendbarkeit	BSI/IT-Grundschutz	ISO-Kennungen
KI-GEL-001	Abgrenzung zum allgemeinen IT-Sicherheitskonzept	standard	ISMS.1, ORP.1	ISO/IEC 27001:2022 4.3, ISO/IEC 27001:2022 6.1
KI-GEL-002	Öffentlicher Referenzstatus und kontrollierte Übernahme	standard	ORP.1, CON.10	ISO/IEC 27001:2022 5.2, ISO/IEC 27002:2022 5.12
KI-GOV-001	KI-Inventar und eindeutige Verantwortung	standard	ORP.1, OPS.1.1.2	ISO/IEC 42001:2023 A.3, ISO/IEC 27001:2022 5.3
KI-GOV-002	Genehmigte Nutzung und KI-Kompetenz	standard	ORP.3, ORP.4	ISO/IEC 42001:2023 A.6, ISO/IEC 27002:2022 6.3
KI-GOV-003	Lebenszyklus-Risikosteuerung, Ausnahmen und Reviews	standard	ISMS.1, OPS.1.1.3	ISO/IEC 27001:2022 6.1, ISO/IEC 42001:2023 6.1, ISO/IEC 23894:2023
KI-REC-001	Rechts- und Datenschutzprüfung je Anwendungsfall	standard	ORP.5, CON.2	ISO/IEC 42001:2023 4.2, ISO/IEC 27001:2022 4.2
KI-REC-002	Schutzbedarf und Geheimschutzgate	standard	CON.10, ORP.4	ISO/IEC 27002:2022 5.12, ISO/IEC 27002:2022 5.13
KI-ARC-001	Explizite Zonen und einziger kontrollierter KI-Zugang	standard	NET.1.1, NET.3.2	ISO/IEC 27002:2022 8.20, ISO/IEC 27002:2022 8.22
KI-ARC-002	Vollständig lokale Datenhaltung und unterbunder Internet-Egress	standard	NET.1.1, OPS.1.1.10	ISO/IEC 27002:2022 5.14, ISO/IEC 27002:2022 8.20
KI-CON-001	Standardmäßig verweiger-te Containerkommunikation	standard	APP.3.4, SYS.1.6	ISO/IEC 27002:2022 8.20, ISO/IEC 27002:2022 8.22

Kontrolle	Titel	Anwendbarkeit	BSI/IT-Grundschutz	ISO-Kennungen
KI-CON-002	Minimale Containerprivilegien und unveränderbare Laufzeit	standard	SYS.1.6, OPS.1.1.2	ISO/IEC 27002:2022 8.9, ISO/IEC 27002:2022 8.27
KI-API-001	Zentrale Authentisierung und Autorisierung am KI-Zugang	standard	ORP.4, APP.6, CON.1	ISO/IEC 27002:2022 5.15, ISO/IEC 27002:2022 5.16, ISO/IEC 27002:2022 8.5
KI-API-002	Serverseitige Modell-, Kontext-, Raten- und Toolgrenzen	standard	APP.6, DER.1	ISO/IEC 27002:2022 8.26, ISO/IEC 27002:2022 8.28
KI-MOD-001	Kontrollierter Modellimport und Provenienz	standard	OPS.1.1.10, OPS.1.1.6	ISO/IEC 27002:2022 5.21, ISO/IEC 27002:2022 8.19
KI-MOD-002	Versionierte Modellfreigabe und Rückrollbarkeit	standard	OPS.1.1.3, OPS.1.1.6	ISO/IEC 42001:2023 A.6, ISO/IEC 5338:2023
KI-TRN-001	Keine Änderung von Modellgewichten	standard	APP.6, OPS.1.1.3	ISO/IEC 42001:2023 A.6, ISO/IEC 5338:2023
KI-RAG-001	Kontrollierte Aufnahme und isolierte Dokumentenaufbereitung	standard	APP.6, SYS.1.6	ISO/IEC 27002:2022 8.7, ISO/IEC 27002:2022 8.26
KI-RAG-002	Durchgängige Berechtigungsprüfung und Indextrennung	standard	ORP.4, APP.6	ISO/IEC 27002:2022 5.15, ISO/IEC 27002:2022 8.3
KI-RAG-003	Schutz, Nachvollziehbarkeit und vollständige Löschung abgeleiteter Daten	standard	CON.6, CON.3	ISO/IEC 27002:2022 8.10, ISO/IEC 27002:2022 8.13, ISO/IEC 5259-1:2024
KI-RAG-004	Sitzungsbezogene On-Demand-Uploads	standard	CON.6, APP.6	ISO/IEC 27002:2022 8.10, ISO/IEC 27002:2022 8.12

Kontrolle	Titel	Anwendbarkeit	BSI/IT-Grundschutz	ISO-Kennungen
KI-IAM-001	Least Privilege und Geheimnisbehandlung für KI-Dienste	standard	ORP.4, CON.7	ISO/IEC 27002:2022 5.15, ISO/IEC 27002:2022 5.16, ISO/IEC 27002:2022 8.2
KI-AGT-001	Minimale lokale Arbeitsbereichs- und Dateirechte	standard	ORP.4, APP.6	ISO/IEC 27002:2022 8.2, ISO/IEC 27002:2022 8.18
KI-AGT-002	Lokale und freigegebene Modellendpunkte	standard	APP.6, NET.1.1	ISO/IEC 27002:2022 8.19, ISO/IEC 27002:2022 8.20
KI-PMT-001	Untrusted Inhalte und indirekte Prompt Injection	standard	APP.6, DER.1	ISO/IEC 27002:2022 8.26, ISO/IEC 27002:2022 8.28
KI-OUT-001	Validierung, Kennzeichnung und menschliche Prüfung von Ausgaben	standard	APP.6, OPS.1.1.6	ISO/IEC 42001:2023 A.8, ISO/IEC 25059:2023
KI-TOL-001	Getrennte Tool-Fähigkeiten und Bestätigung kritischer Aktionen	standard	ORP.4, APP.6	ISO/IEC 27002:2022 8.2, ISO/IEC 27002:2022 8.18
KI-TOL-002	Kontrollierte Erweiterungen, MCP-Server und Tool-Protokollierung	standard	OPS.1.1.10, OPS.1.1.5	ISO/IEC 27002:2022 5.21, ISO/IEC 27002:2022 8.15
KI-THR-001	KI-spezifisches Bedrohungsmodell	standard	DER.1, APP.6	ISO/IEC 27001:2022 6.1, ISO/IEC 23894:2023
KI-THR-002	Ressourcen-, Missbrauchs- und Verfügbarkeitsgrenzen	standard	OPS.1.1.1, DER.1	ISO/IEC 27002:2022 8.6, ISO/IEC 27002:2022 8.16
KI-VAL-001	Reproduzierbare Qualitäts- und Sicherheitsevaluierung	standard	OPS.1.1.6, APP.6	ISO/IEC 42001:2023 A.7, ISO/IEC 25059:2023
KI-VAL-002	Änderungsabhängige Regression, Wiederfreigabe und Rollback	standard	OPS.1.1.3, OPS.1.1.6	ISO/IEC 27002:2022 8.32, ISO/IEC 5338:2023

Kontrolle	Titel	Anwendbarkeit	BSI/IT-Grundschutz	ISO-Kennungen
KI-OPS-001	Datensparsame und manipulationsgeschützte KI-Protokollierung	standard	OPS.1.1.5, DER.1	ISO/IEC 27002:2022 8.15, ISO/IEC 27002:2022 8.17
KI-OPS-002	Monitoring, Drift und KI-Vorfallbehandlung	standard	DER.1, DER.2.1	ISO/IEC 27002:2022 8.16, ISO/IEC 27002:2022 5.24
KI-OPS-003	Wiederanlauf und konsistente Sicherungen	standard	CON.3, DER.4	ISO/IEC 27002:2022 8.13, ISO/IEC 27002:2022 5.30
KI-DEC-001	Kontrollierte Außerbetriebnahme	standard	CON.6, OPS.1.1.2	ISO/IEC 27002:2022 8.10, ISO/IEC 27002:2022 5.11
KI-EXT-001	Neue Bewertung vor externer Inferenz	bedingt-externe-inferenz	OPS.2.2, CON.2	ISO/IEC 27002:2022 5.19, ISO/IEC 27002:2022 5.20, ISO/IEC 42001:2023 A.10
KI-EXT-002	Kein automatischer externer Fallback	bedingt-externe-inferenz	NET.1.1, APP.6	ISO/IEC 27002:2022 8.20, ISO/IEC 27002:2022 8.26
KI-ASS-001	Prüfbare Nachweiskette und befristete Abweichungen	standard	ISMS.1, DER.3.1	ISO/IEC 27001:2022 7.5, ISO/IEC 27001:2022 9.1, ISO/IEC 42001:2023 9.1

14 Verfahren zur organisationsspezifischen Übernahme

Eine Übernahme beginnt niemals durch direkte Ergänzung dieses Referenzrepositorys. Vor der ersten Organisationsangabe wird eine getrennte, angemessen geschützte Offline-Fassung erstellt. Der Statusmechanismus setzt Deckblatt, Kopfzeilen und Metadaten auf die Kennzeichnung, dass eine Einstufung durch die Organisation erforderlich ist.

1. Geltungsbereich, Verantwortliche, Schutz- und Informationsklassifikation durch befugte Stellen festlegen.
2. Reale Architektur ausschließlich in der geschützten Fassung erfassen und Vertrauenszonen sowie Datenflüsse verifizieren.
3. Rechts-, Datenschutz-, Geheimschutz- und Beteiligungsprüfung je Anwendungsfall durchführen.
4. Kontrollanwendbarkeit, Basisabhängigkeiten, konkrete Umsetzung, Nachweise und Restrisiken bestimmen.
5. Technische Negativ- und Wirksamkeitstests in der tatsächlichen Umgebung durchführen.
6. Unabhängige Fachprüfung, Risikofreigabe und gegebenenfalls formale Einstufung dokumentieren.
7. Änderungs-, Vorfall-, Wiederanlauf-, Modellwechsel- und Außerbetriebnahmeverfahren betreiben.

Externe Inferenz ist ein eigener Systemgrenzenwechsel. Sie darf nicht als einfache Konfigurationsvariante übernommen werden, sondern erfordert die vollständige Neubewertung nach KI-EXT-001 und KI-EXT-002.

15 Quellenverzeichnis, Glossar und Abkürzungen

15.1 Quellenverzeichnis

Maßgeblich ist das maschinenlesbare Quellenregister. Die folgenden Angaben verwenden den Prüfstand 02.09.2026. Bei HTML-Dokumentation ohne ausgewiesenes Veröffentlichungsdatum wird ausdrücklich der Abrufstand genannt.

[Q-BMI-001] Bundesministerium des Innern und für Heimat / Beratungszentrum für Künstliche Intelligenz: Leitlinien für den Einsatz Künstlicher Intelligenz in der Bundesverwaltung, Erstfassung, 2025-04-07, S. 25–29; S. 30, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 3-offizielle-empfehlung. Wiedervorlage: 2027-09-02.

[Q-BSI-001] Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, 2025-06-06, S. 4–7; S. 8–10; S. 11–13; S. 14–16, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 3-offizielle-empfehlung. Wiedervorlage: 2027-09-02.

[Q-BMVG-001] Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, 2026-08-04, S. 23–26; S. 28–34; S. 45–50, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 3-offizielle-empfehlung. Wiedervorlage: 2027-09-02.

[Q-BSI-SDT-001] Bundesamt für Sicherheit in der Informationstechnik: Stand-der-Technik-Bibliothek, Commit 8a97764ff4f23c2b7945c64344eecbf5a2053db2, 2026-08-27, Repository-Inhalt und OSCAL-Katalog am fixierten Commit, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 4-veröffentlichte-bsi-struktur. Wiedervorlage: 2027-09-02.

[Q-NIST-OSCAL-001] National Institute of Standards and Technology: OSCAL Version 1.1.3 – Catalog JSON Schema, OSCAL 1.1.3, 2024-11-26, Gesamtes Catalog-JSON-Schema, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 5-internationale-behördenquelle. Wiedervorlage: 2027-09-02.

[Q-EU-001] Europäische Union: Verordnung (EU) 2024/1689 über künstliche Intelligenz, ABl. L 2024/1689, 2024-07-12, Art. 2–4; Art. 9–15; Art. 26 und 27, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 1-recht. Wiedervorlage: 2026-12-01.

[Q-BFDI-001] Die Bundesbeauftragte für den Datenschutz und die Informationsfreiheit: KI in Behörden – Datenschutz von Anfang an mitdenken, Handreichung für die Bundesverwaltung, 2025-12-22, Kap. 1–3; Kap. 4–7, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 3-offizielle-empfehlung. Wiedervorlage: 2027-09-02.

[Q-DSK-001] Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Künstliche Intelligenz und Datenschutz, Version 1.0, 2024-05-06, Gesamtdokument, insbesondere Auswahl, Einführung, Nutzung und Beendigung, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 3-offizielle-empfehlung. Wiedervorlage: 2027-09-02.

[Q-DSK-002] Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu empfohlenen technischen und organisatorischen Maßnahmen bei der Entwicklung und beim Betrieb von KI-Systemen, Version 1.0, 2025-06-17, Kap. 2–6, öffentliche

Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 3-offizielle-empfehlung. Wiedervorlage: 2027-09-02.

[Q-DSK-003] Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu datenschutzrechtlichen Besonderheiten generativer KI-Systeme mit RAG-Methode, Version 1.0, 2025-10-17, Kap. 2–5, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 3-offizielle-empfehlung. Wiedervorlage: 2027-09-02.

[Q-NIST-001] National Institute of Standards and Technology: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, 2024-07-26, Profile actions for Govern, Map, Measure and Manage, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 5-internationale-behördenquelle. Wiedervorlage: 2026-12-01.

[Q-NIST-002] National Institute of Standards and Technology: Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations, NIST AI 100-2 E2025, 2025-03-24, Taxonomie der Angriffe und Abhilfen, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 5-internationale-behördenquelle. Wiedervorlage: 2026-12-01.

[Q-ENISA-001] European Union Agency for Cybersecurity: Multilayer Framework for Good Cybersecurity Practices for AI, Erstveröffentlichung, 2023-11-15, Multilayer framework und good practices, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 5-internationale-behördenquelle. Wiedervorlage: 2026-12-01.

[Q-NCSC-001] UK National Cyber Security Centre und internationale Partner: Guidelines for Secure AI System Development, Version 1.0, 2023-11-26, Secure design, development, deployment, operation and maintenance, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 5-internationale-behördenquelle. Wiedervorlage: 2026-12-01.

[Q-OWASP-001] OWASP Foundation: OWASP Top 10 for Large Language Model Applications, Ausgabe 2025, Abrufstand 02.09.2026, LLM Top 10 2025, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 6-informativer-bedrohungskatalog. Wiedervorlage: 2026-12-01.

[Q-MITRE-001] The MITRE Corporation: MITRE ATLAS, Laufend gepflegte Wissensbasis, Abrufstand 02.09.2026, Tactics and techniques, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 6-informativer-bedrohungskatalog. Wiedervorlage: 2026-12-01.

[Q-K8S-001] The Kubernetes Authors: Kubernetes API Reference: NetworkPolicy v1, Online-Dokumentation, Abrufstand 02.09.2026, NetworkPolicySpec, ingress und egress, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 7-offizielle-produktdokumentation. Wiedervorlage: 2026-12-01.

[Q-DOCKER-001] Docker, Inc.: Rootless mode, Online-Dokumentation, Abrufstand 02.09.2026, Rootless mode, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 7-offizielle-produktdokumentation. Wiedervorlage: 2026-12-01.

[Q-PODMAN-001] Podman Project: podman-network, Online-Dokumentation, Abrufstand 02.09.2026, Network management und network create, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 7-offizielle-produktdokumentation. Wiedervorlage: 2026-12-01.

[Q-OLLAMA-001] Ollama: Authentication, Online-Dokumentation, Abrufstand 02.09.2026, Local access, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 7-offizielle-produktdokumentation. Wiedervorlage: 2026-12-01.

[Q-VLLM-001] vLLM Project: Security, Online-Dokumentation, Abrufstand 02.09.2026, Security und API server, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 7-offizielle-produktdokumentation. Wiedervorlage: 2026-12-01.

[Q-OPENWEBUI-001] Open WebUI: Starting with OpenAI-compatible providers, Online-Dokumentation, Abrufstand 02.09.2026, Connection to OpenAI-compatible providers, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 7-offizielle-produktdokumentation. Wiedervorlage: 2026-12-01.

[Q-OPENWEBUI-002] Open WebUI: API Endpoints, Online-Dokumentation, Abrufstand 02.09.2026, Authentication und API endpoints, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 7-offizielle-produktdokumentation. Wiedervorlage: 2026-12-01.

[Q-CLINE-001] Cline Bot Inc.: Cline Model Providers, Commit 0b0ca9b1fa95ed9f3e0891a34f1f9b3904309710, 2026-05-12, OpenAI-Compatible Providers, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 7-offizielle-produktdokumentation. Wiedervorlage: 2027-09-02.

[Q-OPENCODE-001] Anomaly Innovations Inc.: OpenCode Models, Version 2, Online-Dokumentation, Abrufstand 02.09.2026, Local models und provider configuration, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 7-offizielle-produktdokumentation. Wiedervorlage: 2026-12-01.

[Q-LLAMACPP-001] ggml-org: llama.cpp, Commit ccc8fd2baa64ab26c7210b02765d3604069ec7ee, 2026-08-23, README und llama-server-Verweise, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 7-offizielle-produktdokumentation. Wiedervorlage: 2027-09-02.

[Q-DAKKS-001] Deutsche Akkreditierungsstelle GmbH: Was ist Akkreditierung?, Online-Information, Abrufstand 02.09.2026, Begriffsdefinition Akkreditierung, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 5-internationale-behördenquelle. Wiedervorlage: 2026-12-01.

[Q-BSIG-001] Bundesrepublik Deutschland: Gesetz über das Bundesamt für Sicherheit in der Informationstechnik und über die Sicherheit in der Informationstechnik von Einrichtungen, BSIG 2025, 2025-12-02, Anwendungsbezogen zu prüfende Vorschriften, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 1-recht. Wiedervorlage: 2026-12-01.

[Q-SUEG-001] Bundesrepublik Deutschland: Sicherheitsüberprüfungsgesetz, § 4 Verschlusssachen, SÜG, 1994-04-20, § 4, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 1-recht. Wiedervorlage: 2026-12-01.

[Q-VSA-001] Bundesministerium des Innern und für Heimat: Allgemeine Verwaltungsvorschrift zum materiellen Geheimschutz, Verschlusssachenanweisung, 2023-03-13, Allgemeine Einstufungs- und Handhabungsregeln, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 1-recht. Wiedervorlage: 2026-12-01.

[Q-ISO-27001] International Organization for Standardization / International Electrotechnical Commission: Information security, cybersecurity and privacy protection — Information security management systems — Requirements, ISO/IEC 27001:2022, 2022-10-01, Öffentliche Titelseite,

Abstract und Metadaten, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 5-internationale-standardisierungsquelle. Wiedervorlage: 2026-12-01.

[Q-ISO-27002] International Organization for Standardization / International Electrotechnical Commission: Information security, cybersecurity and privacy protection — Information security controls, ISO/IEC 27002:2022, 2022-02-01, Öffentliche Titelseite, Abstract und Metadaten, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 5-internationale-standardisierungsquelle. Wiedervorlage: 2026-12-01.

[Q-ISO-42001] International Organization for Standardization / International Electrotechnical Commission: Information technology — Artificial intelligence — Management system, ISO/IEC 42001:2023, 2023-12-01, Öffentliche Titelseite, Abstract und Metadaten, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 5-internationale-standardisierungsquelle. Wiedervorlage: 2026-12-01.

[Q-ISO-23894] International Organization for Standardization / International Electrotechnical Commission: Information technology — Artificial intelligence — Guidance on risk management, ISO/IEC 23894:2023, 2023-02-01, Öffentliche Titelseite, Abstract und Metadaten, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 5-internationale-standardisierungsquelle. Wiedervorlage: 2026-12-01.

[Q-ISO-42005] International Organization for Standardization / International Electrotechnical Commission: Information technology — Artificial intelligence (AI) — AI system impact assessment, ISO/IEC 42005:2025, 2025-05-01, Öffentliche Titelseite, Abstract und Metadaten, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 5-internationale-standardisierungsquelle. Wiedervorlage: 2026-12-01.

[Q-ISO-5338] International Organization for Standardization / International Electrotechnical Commission: Information technology — Artificial intelligence — AI system life cycle processes, ISO/IEC 5338:2023, 2023-12-01, Öffentliche Titelseite, Abstract und Metadaten, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 5-internationale-standardisierungsquelle. Wiedervorlage: 2026-12-01.

[Q-ISO-5259] International Organization for Standardization / International Electrotechnical Commission: Artificial intelligence — Data quality for analytics and machine learning (ML) — Part 1, ISO/IEC 5259-1:2024, 2024-07-01, Öffentliche Titelseite, Abstract und Metadaten, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 5-internationale-standardisierungsquelle. Wiedervorlage: 2026-12-01.

[Q-ISO-25059] International Organization for Standardization / International Electrotechnical Commission: Software engineering — SQuaRE — Quality model for AI systems, ISO/IEC 25059:2023, 2023-06-01, Öffentliche Titelseite, Abstract und Metadaten, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 5-internationale-standardisierungsquelle. Wiedervorlage: 2026-12-01.

[Q-BSI-GSK-001] Bundesamt für Sicherheit in der Informationstechnik: IT-Grundschutz-Kompendium – öffentliche Baustein- und Anforderungskennungen, Über die Stand-der-Technik-Bibliothek fixierte Referenz, 2026-08-27, OSCAL-Katalog am fixierten Commit, öffentliche Fundstelle, abgerufen am 02.09.2026. Autoritätsstufe: 4-veröffentlichte-bsi-struktur. Wiedervorlage: 2027-09-02.

15.2 Glossar

Begriff	Bedeutung in dieser Referenz
Agentische Anwendung	Client oder Dienst, der Modellausgaben in Datei-, Tool-, Befehls- oder Netzwerkaktionen überführen kann.
Embedding	Numerische Repräsentation eines Inhalts für Ähnlichkeitssuche; kann Schutzbedarf und Personenbezug der Quelle bewahren.
Feinabstimmung	Veränderung vortrainierter Modellgewichte für Aufgaben oder Datenbestände; innerhalb dieses Konzepts ausgeschlossen.
Inferenz	Ausführung eines vortrainierten Modells zur Erzeugung einer Ausgabe ohne beabsichtigte Änderung der Modellgewichte.
On-Demand-Upload	Temporär und lokal bereitgestelltes Dokument für einen begrenzten Nutzungskontext.
Prompt Injection	Eingabe oder eingebettete Anweisung, die beabsichtigte Regeln, Kontextgrenzen oder Toolentscheidungen beeinflussen soll.
RAG	Retrieval Augmented Generation; lokale Suche liefert freigegebene Textausschnitte als Kontext für die Inferenz.
Untrusted	Nicht als Steueranweisung vertrauenswürdig; der Inhalt kann fehlerhaft oder absichtlich manipuliert sein.

15.3 Abkürzungen

Abkürzung	Langform
ACL	Access Control List
API	Application Programming Interface
BfDI	Die Bundesbeauftragte für den Datenschutz und die Informationsfreiheit
BMI	Bundesministerium des Innern
BMVg	Bundesministerium der Verteidigung
BSI	Bundesamt für Sicherheit in der Informationstechnik
DSK	Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder
IdP	Identity Provider
ISMS	Informationssicherheitsmanagementsystem

Abkürzung	Langform
KI	Künstliche Intelligenz
MFA	Mehrfaktorauthentisierung
MCP	Model Context Protocol
OSCAL	Open Security Controls Assessment Language
RAG	Retrieval Augmented Generation
SIEM	Security Information and Event Management
TLS	Transport Layer Security
VPN	Virtual Private Network